Track E: Data protection and governance

Generated from the same content files as the app. Each module lists its roadmap months. Solutions are in the appendix.

Contents

Track E: Data protection and governance 2

E1 UK GDPR and special category data in HR 3

E1-L1 Personal data, special category data and the two-part test 3

E1-L2 A lawful basis for each use of talent data 7

E1-L3 Article 9 conditions, policy documents and DPIA screening in HR 11

E1-L4 Writing the DPIA for a people model 16

E1-L5 Personal data in each medallion layer 20

E2 DAMA-DMBOK applied to talent data 25

E2-L1 The DAMA wheel, eleven knowledge areas around governance 25

E2-L2 A maturity baseline you can defend 29

E2-L3 Governance at the hub, decision rights, policies and escalation 33

E2-L4 People master data, match rules and survivorship 36

E2-L5 A RACI and a business glossary for talent data 41

E3 Cross-border transfers and works councils 46

E3-L1 Restricted transfers, when people data leaves the UK 46

E3-L2 Choosing a transfer mechanism and the transfer risk assessment 50

E3-L3 Works councils and consultation before people analytics or AI 54

Track E best-practice checklist 61

Appendix: solutions and answer keys 62

Track E: Data protection and governance

The law and the frameworks that govern people data, for the engineer who builds the platform.

E1 UK GDPR and special category data in HR

Roadmap: EY Talent Data Strategy role; Current work. Personal and special category data, lawful bases for talent data, Article 9 conditions, appropriate policy documents and DPIA screening.

E1-L1 Personal data, special category data and the two-part test

Concept

Everything a talent platform holds is **personal data**: names, grades, salaries, review scores, course completions, skills. It relates to an identifiable person, so the UK GDPR applies. The Data Protection Act 2018 sits beside it and adds UK-specific conditions. These lessons follow the ICO's guidance as of November 2026. Your data protection officer and legal team make the final call.

Some personal data needs more protection. The UK GDPR names nine **special categories** in Article 9:

- racial or ethnic origin
- political opinions
- religious or philosophical beliefs
- trade union membership
- genetic data
- biometric data, when you use it to identify someone uniquely
- health
- sex life
- sexual orientation

Three details catch engineers out.

Biometric data is narrow. A staff photo on a profile is not special category data. The same photo used to unlock a door by face recognition is.

Inferences count. A model that infers health, ethnicity or sexual orientation from other fields processes special category data, even when no column is called that.

Protected characteristics are a different list. Age and sex are protected under the Equality Act 2010, but they are not special categories. Sexual orientation and religion are both.

To use any personal data you need a **lawful basis** under Article 6. To use special category data you need a lawful basis **and** an **Article 9 condition**. This is the **two-part test**. Lessons E1-L2 and E1-L3 cover each part.

Why it matters

An HR analytics team built an attrition model from absence records, overtime and the free-text reasons managers gave for sick leave. The model's strongest feature was a word count of "stress" and "anxiety" in those reasons. Nobody had flagged the column, because it was called absence_note. It held health data, so the processing needed an Article 9 condition and a data protection impact assessment that nobody had done. The model was withdrawn for three months while the team removed the field and wrote the assessment.

Worked example: weak code

```
# Attribute register, talent platform
date_of_birth: {sensitive: true}
gender: {sensitive: true}
absence_note: {sensitive: false}
badge_photo: {sensitive: true}
union_rep: {sensitive: false}
```

1. **Line 2.** One yes/no flag mixes up two lists. Age is a protected characteristic, not a special category.
2. **Line 4.** Free text about sick leave holds health data.
3. **Line 6.** Being a union representative reveals trade union membership, a special category.

Worked example: strong code

```
# Attribute register, talent platform
date_of_birth: {special_category: null, protected_characteristic: age}
gender: {special_category: null, protected_characteristic: sex}
absence_note: {special_category: health, protected_characteristic: null}
badge_photo: {special_category: null, note: "biometric only if used to
  identify"}
union_rep: {special_category: trade_union_membership,
  protected_characteristic: null}
```

1. **Line 2.** Two separate fields: the GDPR list and the Equality Act list.
2. **Line 4.** Classified by what the content reveals, not by the column name.

3. **Line 5.** Records the condition that would change the classification.

Classify each attribute by what it reveals. Keep the special categories and the protected characteristics as two separate fields, and treat inferences as data.

Recap card

- **The nine special categories** Racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic, biometric (to identify), health, sex life, sexual orientation.
- **Is an inferred special category special category data?** Yes. A model that infers health or ethnicity processes special category data.
- **Age and sex** Protected characteristics under the Equality Act 2010. Not special categories.
- **The two-part test** An Article 6 lawful basis for all personal data, plus an Article 9 condition for special category data.

Practice

Exercise 1. Multiple choice (level 1)

Which attribute is special category data under Article 9 of the UK GDPR?

- a) Date of birth
- b) Salary band
- c) Trade union membership
- d) Home address

Exercise 2. Multiple choice (level 2)

A model predicts which employees are likely to go on long-term sick leave, from absence patterns and overtime. No input column holds health data. Does the processing involve special category data?

- a) No, because no input column is health data
- b) Yes, because the model infers information about health
- c) Only if the predictions are shown to managers
- d) Only if the model uses more than 1,000 records

Why?

- r1) Inferring a special category from other data counts as processing that category.
- r2) Absence data is always health data.

Exercise 3. Fill the gap (level 2)

Complete the two-part test for using special category data.

```
Part 1: a lawful basis under Article _____(1)
Part 2: a condition under Article _____(2)
```

Exercise 4. Write the function (level 3)

Write `is_special_category(field: dict) -> bool` for an attribute register. `field` has a `"category"` key, such as `"health"` or `"age"`, and may have a `"use"` key. Return True for the nine special categories. Biometric data counts only when `field.get("use") == "identify"`. Keep the category names in a module constant.

The category names are: `"racial_or_ethnic_origin"`, `"political_opinions"`, `"religious_or_philosophical_beliefs"`, `"trade_union_membership"`, `"genetic"`, `"biometric"`, `"health"`, `"sex_life"` and `"sexual_orientation"`.

Your code must pass these checks:

- Return True for each of the nine special categories.
- Age and sex are protected characteristics, not special categories. Salary and address are ordinary personal data.
- Biometric data is special category data only when you use it to identify someone uniquely.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```python
# Module constant.
SPECIAL_CATEGORIES = ...

# True when an attribute is special category data under Article 9.
def is_special_category(field: dict) -> bool: ...
```

Starter code:

```python
def is_special_category(field):
    return field["category"] in {"health", "age", "biometric"}
```

Exercise 5. Architecture design (level 4)

Design the classification fields for a talent attribute register that feeds access rules and DPIA screening.

Options: special_category and protected_characteristic as separate fields, One sensitive: true/false flag.

1. Fields for sensitivity
2. How an attribute is classified

3. Model outputs

Sources

- UK GDPR Article 9 lists nine special categories; biometric data counts only when used to identify someone uniquely; age is not among them but is a protected characteristic under section 4 of the Equality Act 2010; special category data needs an Article 6 basis and an Article 9 condition. (verified: https://www.legislation.gov.uk/eur/2016/679/article/9 and https://www.legislation.gov.uk/ukpga/2010/15/section/4, checked 7 November 2026.)
- Inferring a special category means processing special category data. (search-only: ICO guidance pages 'What is special category data?', 'Biometric recognition: key data protection concepts' and 'What about fairness, bias and discrimination?' (ico.org.uk), seen through search results, November 2026. ico.org.uk was not reachable from the build environment.)
- The Data Protection Act 2018 supplements the UK GDPR with UK-specific conditions in Schedule 1. (verified: https://www.legislation.gov.uk/ukpga/2018/12/section/10, checked 7 November 2026.)

E1-L2 A lawful basis for each use of talent data

Concept

Article 6 of the UK GDPR gives **seven lawful bases**. Each use of personal data needs one that fits it:

- **consent**
- **contract**, to perform a contract with the person, such as paying their salary
- **legal obligation**, such as tax reporting or right-to-work checks
- **vital interests**, to protect someone's life
- **public task**
- **legitimate interests**
- **recognised legitimate interests**

The seventh came with the Data (Use and Access) Act 2025 on 5 February 2026. It covers only the purposes listed in Annex 1 of the UK GDPR, such as safeguarding, crime and emergencies, and it has no balancing test. Workforce analytics is not on the list.

Employers rarely rely on consent. The ICO's view is that the power imbalance between employer and worker makes it hard for consent to be freely given. A worker who fears saying no has no genuine choice. Use another basis.

Workforce analytics usually rests on **legitimate interests**. The ICO describes a **three-part test**, recorded in a **legitimate interests assessment** (LIA) before processing starts:

1. **Purpose**: is there a legitimate interest?
2. **Necessity**: does the processing serve it, and is there a less intrusive way?
3. **Balancing**: do the person's interests, rights and freedoms override yours? Ask what a reasonable person would expect.

Two principles from Article 5 shape the platform. **Purpose limitation**, Article 5(1)(b): a basis covers the purposes you specified. Payroll under contract does not cover an attrition model. A new purpose needs its own check. **Data minimisation**, Article 5(1)(c): hold only the data each purpose needs.

Why it matters

A firm launched an engagement survey and stated that consent was its lawful basis. Two years later it fed the answers into a promotion-readiness model. Staff complained that they had never agreed to that use, and some withdrew consent, which removed their records from every analysis. A legitimate interests assessment for each purpose, done before launch, would have shown that the promotion use failed the balancing test.

Worked example: weak code

```
  1 # Processing register, talent platform
(1) payroll: {lawful_basis: consent}
  3 engagement_survey: {lawful_basis: consent}
(2) attrition_model: {lawful_basis: same as payroll}
```

1. **Line 2.** Workers cannot refuse payroll. Consent cannot be freely given here.
2. **Line 4.** A new purpose needs its own basis check. Payroll's basis does not stretch to it.

Worked example: strong code

```
  1 # Processing register, talent platform
(1) payroll: {lawful_basis: contract}
  3 tax_reporting: {lawful_basis: legal_obligation}
(2) engagement_survey: {lawful_basis: legitimate_interests, lia: LIA-007}
```

```
❸ attrition_model: {lawful_basis: legitimate_interests, lia: LIA-012,
    fields: minimised}
```

1. **Line 2.** Paying salary performs the employment contract.
2. **Line 4.** Each use of legitimate interests points to its recorded assessment.
3. **Line 5.** Its own assessment, and only the fields the model needs.

Give each purpose its own lawful basis, avoid consent for workers, record a legitimate interests assessment for each use of legitimate interests, and keep only the fields each purpose needs.

Recap card

- **The seven lawful bases** Consent, contract, legal obligation, vital interests, public task, legitimate interests, and recognised legitimate interests since 5 February 2026.
- **Consent for employee data** Rarely appropriate. The power imbalance makes it hard to give freely. Use another basis.
- **Legitimate interests assessment** Purpose, necessity, balancing, recorded before processing starts.
- **Purpose limitation** A basis covers the purposes you specified. A new purpose, such as an attrition model, needs its own check.
- **Recognised legitimate interests** Article 6(1)(ea), from 5 February 2026. Only the purposes in Annex 1, with no balancing test.

Practice

Exercise 1. Multiple choice (level 1)

Which lawful basis fits paying an employee's salary?

- a) Consent
- b) Contract
- c) Vital interests
- d) Public task

Exercise 2. Multiple choice (level 2)

A team wants to use consent as the lawful basis for a voluntary skills survey of its own employees. What does the ICO's guidance say?

- a) Consent is the safest basis for any employee data
- b) Employers rarely rely on consent, because the power imbalance makes it hard to give freely
- c) Consent is banned for employees

- d) Consent is required for any survey

Why?

- r1) A worker who fears refusing has no genuine choice, so consent is hard to show as freely given.
- r2) Consent expires after one year.

Exercise 3. Put in order (level 2)

Put the steps of a legitimate interests assessment in order.

- Balancing: weigh the person's interests, rights and freedoms against yours
- Purpose: identify the legitimate interest
- Record the outcome before processing starts
- Necessity: show the processing serves it and nothing less intrusive would

Exercise 4. Fill the gap (level 3)

Complete the two principles that shape a talent platform.

```
Purpose _____(1): a lawful basis covers the purposes you specified. A new purpose needs its own check.
Data _____(2): hold only the data each purpose needs.
```

Exercise 5. Architecture design (level 4)

Choose the lawful basis for each use of a talent platform's data.

Options: Legal obligation, Consent, Legitimate interests.

1. Right-to-work checks before someone starts
2. Recording mandatory training completions
3. A new attrition prediction model

Sources

- Article 6(1) lists seven lawful bases since 5 February 2026; point (ea) is recognised legitimate interest. Purpose limitation is Article 5(1)(b) and data minimisation Article 5(1)(c). Article 8A sets the test for whether a new purpose is compatible. (verified: https://www.legislation.gov.uk/eur/2016/679/article/6, /article/5 and /article/8A, checked 7 November 2026.)
- Consent is not usually appropriate for employers because of the imbalance of power; not banned where refusing has no adverse consequences. (search-only: ICO guidance 'Data protection and monitoring workers' and 'Data protection and workers' health information' (ico.org.uk), seen through search results, November 2026.)

- Legitimate interests three-part test: purpose, necessity, balancing; reasonable expectations judged objectively; record in an LIA before processing. (search-only: ICO guidance 'What is the legitimate interests basis?' and 'Legitimate interests' (ico.org.uk), seen through search results, November 2026.)
- Recognised legitimate interests came into force on 5 February 2026 (section 70, SI 2026/82). Under Article 6(5) the basis applies only if processing meets a condition in Annex 1, with no balancing clause. (verified: https://www.legislation.gov.uk/uksi/2026/82/made and https://www.legislation.gov.uk/eur/2016/679/article/6, checked 7 November 2026.)

E1-L3 Article 9 conditions, policy documents and DPIA screening in HR

Concept

Article 9(2) of the UK GDPR lists ten conditions for special category data. Two carry most HR work, and in the UK both need an extra condition from **Schedule 1 of the Data Protection Act 2018**.

Article 9(2)(b), employment, social security and social protection. It covers duties and rights in employment law, such as recording sickness absence or making reasonable adjustments. The UK condition is Schedule 1, Part 1, **paragraph 1**. It does not cover purely contractual rights.

Article 9(2)(g), substantial public interest. It needs one of the 23 conditions in Schedule 1, **paragraphs 6 to 28**. Diversity monitoring usually relies on **paragraph 8, equality of opportunity or treatment**. It covers four categories only: racial or ethnic origin, religious or philosophical beliefs, health, and sexual orientation. Paragraph 8 supports reviewing equality across groups. It cannot support a decision about one person, so keep monitoring data apart from promotion or hiring decisions.

Both routes need an **appropriate policy document** (APD). The ICO says it needs no set form. It names the Schedule 1 condition, explains how you meet the principles, and sets your retention and erasure rules. One APD can cover several purposes. Your record of processing activities also names the condition.

Before you start processing likely to result in **high risk**, carry out a **data protection impact assessment** (DPIA) under Article 35. Three cases

always need one, including **large-scale special category or criminal offence data** and extensive profiling with significant effects. The ICO's list adds others, such as innovative technology like AI combined with another risk factor. Two risk factors usually mean a DPIA. If you cannot reduce a high risk, consult the ICO before you start. Since 30 September 2026 the ICO is the Information Commission's Office.

Why it matters

A retailer used its equal opportunities survey, collected under paragraph 8, to pick candidates for a leadership programme that favoured under-represented groups. The survey data now drove decisions about individuals, which paragraph 8 does not support. The programme paused while the team rebuilt it on aggregate statistics and a separate, voluntary application form.

Worked example: weak code

```
  1 # Special category register
❶ sickness_absence: {article_9: 9(2)(b)}
❷ ethnicity: {article_9: 9(2)(g), used_for: [diversity_report,
    promotion_shortlist]}
❸ dpia: not needed, internal data only
```

1. **Line 2.** No Schedule 1 condition and no appropriate policy document.
2. **Line 3.** Paragraph 8 supports monitoring, not decisions about individuals.
3. **Line 4.** Large-scale special category data needs a DPIA, internal or not.

Worked example: strong code

```
  1 # Special category register
❶ sickness_absence: {article_9: 9(2)(b), schedule_1: "Part 1 para 1", apd:
    APD-HR-01}
❷ ethnicity: {article_9: 9(2)(g), schedule_1: "Part 2 para 8", apd: APD-
    HR-01, used_for: [diversity_report]}
❸ dpia: DPIA-014, screened for large-scale special category data and
    profiling
```

1. **Line 2.** Article 9 condition, Schedule 1 condition and the policy document, side by side.
2. **Line 3.** Monitoring only. No individual decisions.
3. **Line 4.** The screening reason is recorded with the assessment.

Pair each Article 9 condition with its Schedule 1 condition and an appropriate policy document, keep monitoring data away from individual decisions, and screen every new use for a DPIA.

Recap card

- **Employment condition in the UK** Article 9(2)(b) plus Schedule 1, Part 1, paragraph 1 of the DPA 2018, with an appropriate policy document.
- **Diversity monitoring** Article 9(2)(g) plus Schedule 1 paragraph 8, equality of opportunity or treatment. Never for decisions about one person.
- **Appropriate policy document** Names the Schedule 1 condition, how you meet the principles, and retention and erasure. One APD can cover several purposes.
- **When a DPIA is mandatory** Before high-risk processing, always for large-scale special category data and extensive profiling with significant effects. Consult the ICO if high risk remains.

Practice

Exercise 1. Multiple choice (level 1)

Which conditions does diversity monitoring of employees usually rely on?

- a) Article 9(2)(g) with Schedule 1 paragraph 8, equality of opportunity or treatment
- b) Article 9(2)(b) with Schedule 1 paragraph 1
- c) Consent from each employee
- d) No condition, because the data is aggregated afterwards

Exercise 2. Multiple choice (level 2)

A team wants to use the ethnicity answers from the equal opportunities survey to shortlist candidates for a promotion programme. What is the problem?

- a) None, the data is already collected
- b) Paragraph 8 supports monitoring equality across groups, not decisions about one person
- c) Ethnicity is not special category data
- d) The survey must be repeated each year

Why?

- r1) The ICO says the equality condition cannot be relied on when processing is for decisions about a particular individual.
- r2) Survey data expires after six months.

Exercise 3. Fill the gap (level 2)

Complete the documentation rule for the employment condition.

```
Article 9(2)(b) in the UK needs Schedule 1, Part 1, paragraph _____(1)
and an appropriate _____(2) document that names the condition and the
    retention rules.
```

Exercise 4. Write the function (level 3)

Write `check_register(entries: list[dict]) -> list[str]` for a processing register. Each entry has `"attribute"`, `"special"` (a bool), `"lawful_basis"`, `"condition"`, `"schedule1"` and `"apd"` (a bool). `"condition"` and `"schedule1"` may be None. Return one message per problem, in register order:

- `"<attribute>: no lawful basis"` when `lawful_basis` is not one of the six bases (`"consent"`, `"contract"`, `"legal_obligation"`, `"vital_interests"`, `"public_task"`, `"legitimate_interests"`)
- `"<attribute>: no Article 9 condition"` when the attribute is special and `condition` is None
- `"<attribute>: no Schedule 1 condition"` when `condition` is `"9(2)(b)"` or `"9(2)(g)"` and `schedule1` is None
- `"<attribute>: no appropriate policy document"` when `condition` is one of those two and `apd` is False

Keep the bases and the two conditions in module constants.

What you need to know.

`entry["schedule1"] is None` tests for a missing value without treating an empty string as missing. A list collects messages in order:

```
notes = []
notes.append("first")
notes.append("second")   # ["first", "second"]
```

Your code must pass these checks:

- A complete special entry and an ordinary entry raise no problems.
- Flag a lawful basis that is not one of the six.
- A special attribute needs an Article 9 condition.
- 9(2)(b) and 9(2)(g) need a Schedule 1 condition and an appropriate policy document.
- Return the problems in register order, not sorted.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# Module constant.
```

```
LAWFUL_BASES = ...

# Module constant.
NEEDS_SCHEDULE_1 = ...

# List the documentation gaps in a processing register.
def check_register(entries: list[dict]) -> list[str]: ...
```

Starter code:

```
def check_register(entries):
    return []
```

Exercise 5. Architecture design (level 4)

Screen a new use of talent data for a DPIA: a model that ranks all 40,000 employees for promotion readiness, using performance ratings, absence history and inferred health risk.

Options: Yes: large-scale special category data and profiling with significant effects, No: the data is internal and already held.

1. Is a DPIA needed?
2. When
3. If a high risk remains after mitigation

Sources

- Article 9(2)(b) relies on DPA 2018 Schedule 1 Part 1 paragraph 1 and needs an appropriate policy document; the employment condition does not cover purely contractual rights; APD needs no set form, outlines condition, principles procedures and retention; one APD can cover several purposes; record of processing activities must note the condition. (search-only: ICO guidance 'What are the conditions for processing?', 'What are the rules on special category data?' and 'Data protection and monitoring workers' (ico.org.uk), seen through search results, November 2026.)
- Schedule 1 paragraphs 6 to 28 hold 23 substantial public interest conditions and paragraph 5 requires an APD. Paragraph 8 covers racial or ethnic origin, religious or philosophical beliefs, health and sexual orientation only, and excludes measures or decisions about a particular data subject. The 2025 Act added no new paragraph; it amended paragraphs 10, 13, 14, 23 and 24. (verified: https://www.legislation.gov.uk/ukpga/2018/12/schedule/1, checked 7 November 2026.)
- Paragraph 8 equality of opportunity or treatment is the usual condition for diversity monitoring with Article 9(2)(g). (search-only: ICO guidance 'What

are the substantial public interest conditions?' and 'What about fairness, bias and discrimination?' (ico.org.uk), seen through search results, November 2026.)

- Article 35(3): large-scale special category or criminal offence data, systematic extensive profiling with significant effects and large-scale public monitoring always need a DPIA. Article 36(1): consult the Commission before processing if the DPIA shows a high risk without mitigation. The Information Commission replaced the Information Commissioner on 30 September 2026 and keeps the ICO name. (verified: https://www.legislation.gov.uk/eur/2016/679/article/35 and /article/36, checked 7 November 2026; Lewis Silkin and LexisNexis on the 30 September 2026 commencement.)
- The ICO's list of likely high-risk processing includes innovative technology such as AI combined with another criterion; two screening criteria usually indicate a DPIA. (search-only: ICO guidance 'When do we need to do a DPIA?' and 'Examples of processing likely to result in high risk' (ico.org.uk), seen through search results, November 2026.)

E1-L4 Writing the DPIA for a people model

Concept

Lesson E1-L3 showed when you need a DPIA. This lesson covers writing one for a model that scores people, such as attrition risk or promotion readiness.

UK GDPR **Article 35(7)** sets the minimum content:

1. a systematic **description** of the processing and its purposes;
2. an assessment of **necessity and proportionality**;
3. an assessment of the **risks** to people's rights and freedoms;
4. the **measures** that address those risks.

The ICO's sample template turns this into seven steps: identify the need, describe the processing, consult, assess necessity, identify and assess risks, identify measures, then sign off and record outcomes. You may adapt it.

Risks. For each risk, rate the likelihood of harm (remote, possible, probable) and its severity (minimal, significant, severe), then give an overall rating of low, medium or high. For a people model, name the harms plainly: a manager treats someone as a flight risk, or a group gets fewer promotion nominations.

Fairness belongs in the risk section. Report the test from lesson B13-L3: the model's flag rate for each group defined by a protected characteristic, the ratio between groups, and the threshold that would trigger action. A DPIA that says "the model is fair" with no figures is a statement, not an assessment.

Measures and residual risk. For each medium or high risk, record the measure, its effect (eliminated, reduced or accepted) and the residual risk.

Sign-off. Record the data protection officer's advice and who accepted each residual risk. If a high risk remains, you must consult the ICO before processing starts. Review the DPIA when the model, the data or the purpose changes.

Why it matters

A firm's DPIA for a promotion-readiness model said "bias has been considered". A year later, an internal review found women were flagged as ready at 0.6 times the rate of men with the same ratings. The DPIA held no fairness figures, no threshold and no owner, so nobody had checked. A DPIA with the flag-rate ratio and a trigger would have caught it at the first quarterly review.

Worked example: weak code

```
# DPIA, promotion-readiness model
risks: bias has been considered
measures: the model will be monitored
sign_off: project manager
```

1. **Line 2.** No harm named, no likelihood, no severity, no figures.
2. **Line 3.** No metric, no threshold, no owner, no residual risk.
3. **Line 4.** No DPO advice recorded, and nobody named as accepting each residual risk.

Worked example: strong code

```
# DPIA, promotion-readiness model, version 2
risks:
  - id: R1
    harm: a group receives fewer promotion nominations
    likelihood: possible
    severity: severe
    overall: high
    evidence: flag rate women 0.21, men 0.30, ratio 0.70 on 2025 data
measures:
  - risk: R1
```

```
11      measure: recalibrate thresholds per review cycle; quarterly flag-rate
        ratio check, action below 0.80
12      effect: reduced
3       residual: medium
14      approved_by: HR director
15  dpo_advice: proceed with the quarterly check; review at the next model
        version
4   ico_consultation: not needed, no high residual risk
```

1. **Line 4.** The harm in plain words, to people, not to the project.
2. **Line 8.** Figures from the fairness test, with the data they came from.
3. **Line 13.** The risk after the measure, which decides whether to consult the ICO.
4. **Line 16.** The Article 36 question, answered explicitly.

Cover the four parts of Article 35(7). Name each harm, rate it, put fairness figures in the risk section, record measures and residual risk, and consult the ICO if a high risk remains.

Recap card

- **Article 35(7): four required parts of a DPIA** Description and purposes, necessity and proportionality, risks to people, and the measures that address them.
- **ICO template risk scales** Likelihood: remote, possible, probable. Severity: minimal, significant, severe. Overall: low, medium, high.
- **Where fairness goes in a DPIA** In the risk section, with flag rates per group, the ratio and the threshold for action.
- **High residual risk** Consult the ICO before processing starts.

Practice

Exercise 1. Multiple choice (level 1)

Which item is not one of the four parts Article 35(7) requires in a DPIA?

- a) A return on investment calculation
- b) A description of the processing and its purposes
- c) An assessment of necessity and proportionality
- d) The measures that address the risks

Exercise 2. Multiple choice (level 2)

After measures, one risk of a people model is still rated high. What must happen before processing starts?

- a) Consult the ICO

- b) The project manager signs off the risk
- c) Nothing, as long as the DPIA is written
- d) Ask employees for consent

Why?

- r1) A high risk you cannot mitigate requires prior consultation with the ICO.
- r2) Every DPIA must be sent to the ICO.

Exercise 3. Fill the gap (level 2)

Complete the rating scales from the ICO's sample template.

```
Likelihood of harm:  remote, possible, _____(1)
Severity of harm:    minimal, significant, _____(2)
Overall risk:        low, medium, _____(3)
```

Exercise 4. Write the function (level 3)

Write `dpia_outcome(risks: list[dict]) -> tuple[str, list[str]]`. Each risk is a dict with `"id"` and `"residual"`, where `"residual"` is `"low"`, `"medium"` or `"high"`.

Return `("consult_ico", ids)` with the sorted IDs of every risk whose residual is `"high"`, if there are any. Otherwise return `("proceed", [])`.

Raise `ValueError` if the list is empty, because a DPIA with no risks assessed is not finished, or if any residual is not one of the three levels.

What you need to know.

A list comprehension with a condition keeps matching items:

```
scores = [{"name": "a", "band": "top"}, {"name": "b", "band": "low"}]
[s["name"] for s in scores if s["band"] == "top"]   # ["a"]
```

A function can return a tuple of two values: `return ("ok", [])`.

Your code must pass these checks:

- Return consult_ico with the sorted IDs of every high residual risk.
- With no high residual risk, return ("proceed", []).
- Raise ValueError for an empty list. No risks assessed means the DPIA is not finished.
- Raise ValueError for a residual level other than low, medium or high.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# Module constant.
LEVELS = ...
```

```python

# Whether a DPIA can proceed or needs prior consultation with the ICO.
def dpia_outcome(risks: list[dict]) -> tuple[str, list[str]]: ...
```

Starter code:

```python
def dpia_outcome(risks):
    return ("proceed", [])
```

Exercise 5. Architecture design (level 4)

Plan the DPIA for an attrition-risk model that HR business partners will see for each employee.

Options: Flag rates per group for each protected characteristic held, the ratio, and the action threshold, A statement that the vendor tested the model for bias.

1. Fairness in the risk section
2. Consultation step
3. When to review the DPIA

Sources

- UK GDPR Article 35(7) requires at least a systematic description of the processing and its purposes, an assessment of necessity and proportionality, an assessment of the risks to rights and freedoms, and the measures envisaged to address them. (search-only: Article 35(7) text as retained in UK GDPR. Not re-checked against legislation.gov.uk, which was not reachable.)
- The ICO's sample DPIA template has seven steps and rates likelihood (remote, possible, probable), severity (minimal, significant, severe) and overall risk (low, medium, high); measures record effect (eliminated, reduced, accepted) and residual risk; if a high residual risk is accepted, consult the ICO before going ahead. (search-only: ICO sample DPIA template and the Annex D template of the Age Appropriate Design Code, seen through search results and mirrored copies, November 2026.)

E1-L5 Personal data in each medallion layer

Concept

A medallion design decides where personal data lives in a readable form. Make that decision per layer, and write it down.

Bronze keeps the delivery as received, names and national insurance numbers included. Few people need it: give access to the pipeline identity and one named engineering group. Keep it only as long as reprocessing needs it.

Silver is where you **pseudonymise**. UK GDPR Article 4(5) defines pseudonymisation as processing personal data so it can no longer be attributed to a person without additional information, which is kept separately and protected. In practice:

- Replace each direct identifier with a **keyed hash**, such as HMAC-SHA256 of the employee ID with a secret key.
- Keep the key in a secret store, not in the lakehouse. Without the key, nobody can rebuild the mapping.
- Drop fields no use needs, and coarsen others: date of birth becomes an age band.

A plain hash without a key is not enough. National insurance numbers follow a known pattern, so anyone can hash every possible value and match them.

Pseudonymised data is **still personal data**: you hold the key. It lowers the risk, so it changes how you protect the data, not whether the law applies.

Gold serves aggregates. Suppress any group smaller than a threshold you agree with the data protection officer, such as fewer than 10 people, so a team of three cannot be singled out. Mask any identifying column that remains with column-level security, as lesson C9-L2 showed.

Record each layer's choices in the architecture decision record, with the reason.

Why it matters

A team hashed employee IDs in silver with plain SHA-256 and shared the tables with an analytics vendor. A vendor analyst hashed every employee ID in the firm's known format and matched them all within an hour. The hashed tables were as identifying as the originals. A keyed hash, with the key kept by the firm, would have made the match impossible.

Worked example: weak code

```
1 import hashlib
2
3
1 def mask_id(employee_id):
```

```
(2)      return hashlib.sha256(employee_id.encode()).hexdigest()
```

1. **Line 4.** No check for an empty ID, which would hash to the same value every time.
2. **Line 5.** No key. Anyone can hash every ID in the known format and match them.

Worked example: strong code

```
 1 import hashlib
 2 import hmac
 3
 4
(1) def pseudonymise(employee_id: str, key: bytes) -> str:
 6     """A keyed pseudonym for an employee ID; the key stays in the secret
       store."""
 7     if not employee_id or not key:
 8         raise ValueError("employee ID and key are both required")
(2)     return hmac.new(key, employee_id.encode(), hashlib.sha256).hexdigest()
```

1. **Line 5.** The key is a parameter, read from a secret store at run time, never hardcoded.
2. **Line 9.** HMAC-SHA256 with a secret key. Without the key, the mapping cannot be rebuilt.

Keep raw identifiers in bronze for a few people, pseudonymise with a keyed hash in silver, suppress small groups in gold, and record each choice. Pseudonymised data is still personal data.

Recap card

- **Pseudonymisation, UK GDPR Article 4(5)** Data no longer attributable to a person without additional information that is kept separately and protected.
- **Is pseudonymised data personal data?** Yes. You hold the key. It lowers the risk; the law still applies.
- **Why a keyed hash?** A plain hash of a known-format ID is matched by hashing every possible value. HMAC with a secret key prevents that.
- **Personal data per layer** Bronze raw for a named few, silver pseudonymised, gold aggregated with small groups suppressed.

Practice

Exercise 1. Multiple choice (level 1)

In which layer should direct identifiers be replaced with pseudonyms?

- a) Silver
- b) Bronze

- c) Gold only
- d) None, because access control is enough

Exercise 2. Multiple choice (level 2)

Silver holds employee IDs replaced by a keyed hash. Is it still personal data under UK GDPR?

- a) Yes
- b) No

Why?

- r1) The organisation holds the key and can attribute the data to a person, so it is pseudonymised, not anonymous.
- r2) Any data about employees is personal data, even when no one can identify anyone.

Exercise 3. Fill the gap (level 2)

Complete the plan for personal data in each layer.

```
bronze: raw, read by the pipeline identity and one _____(1) group
silver: direct identifiers replaced by a _____(2) hash, key in the secret
    store
gold:   aggregates, with groups under 10 people _____(3)
```

Exercise 4. Write the function (level 3)

Write `pseudonymise(employee_id: str, key: bytes) -> str`. Return the HMAC-SHA256 of the employee ID, encoded as UTF-8, under `key`, as a hex string. Raise `ValueError` if the ID is empty or the key is empty.

What you need to know.

`hmac.new(key, message, hashlib.sha256)` builds a keyed hash. `.hexdigest()` returns it as hex text. Both arguments must be bytes, so encode text first:

```
import hashlib
import hmac

hmac.new(b"secret", "hello".encode(), hashlib.sha256).hexdigest()[:8]   #
    '88aab3ed'
hashlib.sha256("hello".encode()).hexdigest()[:8]
    # '2cf24dba', no key
```

The same message and key always give the same result. A different key gives a different one.

Your code must pass these checks:

- Return the HMAC-SHA256 of the ID under the key, not a plain hash.

- The same ID and key always give the same pseudonym; a different key or ID gives a different one.
- Raise ValueError for an empty ID or an empty key.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```python
# A keyed pseudonym for an employee ID.
def pseudonymise(employee_id: str, key: bytes) -> str: ...
```

Starter code:

```python
import hashlib


def pseudonymise(employee_id, key):
    return hashlib.sha256(employee_id.encode()).hexdigest()
```

Exercise 5. Architecture design (level 4)

Set the personal data rules for a performance-ratings pipeline.

Options: The pipeline identity and one named engineering group, with short retention, Everyone in the analytics workspace, so they can debug.

1. Bronze access
2. Identifiers in silver
3. Small teams in gold

Sources

- UK GDPR Article 4(5) defines pseudonymisation as processing personal data so it can no longer be attributed to a specific data subject without additional information, kept separately and subject to technical and organisational measures. (verified: https://www.legislation.gov.uk/eur/2016/679/article/4, checked 7 November 2026.)
- Pseudonymised data remains personal data when the controller can attribute it with additional information it holds. (search-only: UK GDPR recital 26 and ICO guidance on pseudonymisation, not re-checked at source: ico.org.uk refused automated requests.)
- Small-cell suppression thresholds, such as fewer than 10 people, are an organisational choice agreed with the data protection officer, not a legal figure. (unverified: Common statistical disclosure control practice.)

E2 DAMA-DMBOK applied to talent data

Roadmap: EY Talent Data Strategy role; Current work. The eleven knowledge areas, governance at the hub, and an evidence-based maturity baseline across talent domains.

E2-L1 The DAMA wheel, eleven knowledge areas around governance

Concept

The **DAMA-DMBOK** (Data Management Body of Knowledge, second edition, revised in 2024) gives data teams a shared map. It splits data management into **eleven knowledge areas**, drawn as a wheel.

Data governance sits at the hub. It decides and oversees how the other ten are run. DMBOK2 defines it as the exercise of authority, control and shared decision-making (planning, monitoring and enforcement) over the management of data assets.

The ten spokes, with a talent example for each:

Knowledge area	Talent example
Data architecture	Bronze, silver and gold layers for HR data
Data modelling and design	The person, position and organisation entities
Data storage and operations	Lakehouse tables, backups, retention jobs
Data security	Masking salary and health fields
Data integration and interoperability	Feeds from the HR system and the learning platform
Document and content management	Contracts, review forms, scanned certificates
Reference and master data	One golden record per person, job codes, grades
Data warehousing and business intelligence	Headcount and attrition reports
Metadata management	Glossary entries, lineage, owners
Data quality	Rules for missing managers or duplicate employee IDs

Two pairs get confused. **Reference data** is a controlled list of codes, such as grades or country codes. **Master data** is the agreed record of a core entity, such as the person. **Metadata** describes data: definitions, owners, lineage. **Master data** is the data itself.

The wheel is a checklist, not an org chart. A talent platform touches all eleven areas. When something breaks, name the area first, then the owner. A duplicate employee is a master data problem, not a reporting bug.

Why it matters

A firm's headcount report disagreed with payroll by 312 people. The BI team spent six weeks tuning report filters. The cause was in master data: contractors re-hired through an agency got a second employee ID, and nothing matched them to their first record. Naming the knowledge area on day one would have sent the problem to the master data owner.

Worked example: weak code

```
1 # Issue log, talent platform
2 - issue: headcount differs from payroll by 312
(1)   owner: BI team
(2)   fix: adjust the report filter
```

1. **Line 3.** The report shows the symptom. The cause sits in another knowledge area.
2. **Line 4.** Fixing the symptom hides the duplicate records from every other consumer.

Worked example: strong code

```
1 # Issue log, talent platform
2 - issue: headcount differs from payroll by 312
(1)   knowledge_area: reference and master data
4   root_cause: re-hired contractors get a second employee ID
(2)   owner: people master data owner
6   fix: match rule on national insurance number and date of birth, then
      merge
```

1. **Line 3.** Name the area first. It points at the right owner.
2. **Line 5.** Governance names an owner for each area and domain.

Name the knowledge area before you name the fix. Governance at the hub assigns an owner to each area, so problems reach the person who can solve them.

Recap card

- **DAMA wheel** Data governance at the hub, ten knowledge areas around it. DMBOK2, revised in 2024.
- **DMBOK2 definition of data governance** The exercise of authority, control and shared decision-making (planning, monitoring and enforcement) over the management of data assets.
- **Reference data, master data, metadata** Reference: lists of codes. Master: the agreed record of a core entity. Metadata: data about data.
- **First move on any data problem** Name the knowledge area, then its owner, then the fix.

Practice

Exercise 1. Multiple choice (level 1)

Which knowledge area sits at the hub of the DAMA wheel?

- a) Data architecture
- b) Data governance
- c) Data quality
- d) Metadata management

Exercise 2. Multiple choice (level 2)

Re-hired contractors get a second employee ID, so headcount is overstated. Which knowledge area owns the root cause?

- a) Data warehousing and business intelligence
- b) Reference and master data
- c) Document and content management
- d) Data storage and operations

Why?

- r1) Master data keeps one agreed record per core entity, such as a person.
- r2) Reference data controls the format of employee IDs.

Exercise 3. Fill the gap (level 2)

Complete the two definitions that are easy to confuse.

```
_____(1) data: a controlled list of codes, such as grades or country codes
_____(2): data about data, such as definitions, owners and lineage
```

Exercise 4. Architecture design (level 3)

Send each talent data problem to its knowledge area.

Options: Data security, Data quality, Data warehousing and business intelligence.

1. Analysts can read salaries they should not see
2. Two teams define 'active employee' differently
3. 12% of records have no manager

Exercise 5. Architecture design (level 4)

You start a new governance role on a talent platform. Choose how to use the DAMA wheel in your first month.

Options: Map all eleven areas to the six talent domains, then pick where to start, Start with the area you know best and add others later.

1. Scope
2. Owners
3. How the wheel is used

Sources

- DAMA-DMBOK2 has eleven knowledge areas with data governance at the centre of the wheel: data architecture, data modelling and design, data storage and operations, data security, data integration and interoperability, document and content management, reference and master data, data warehousing and business intelligence, metadata management and data quality. (verified: DAMA-DMBOK2, checked in the printed book by the course owner, 7 November 2026: chapter 1, the DAMA Wheel figure.)
- The 2024 revision of DMBOK2 kept the DAMA Wheel and its eleven knowledge areas. (verified: Confirmed by the course owner from the revised edition, 7 November 2026.)
- DMBOK2 chapter 3, section 1, defines data governance as 'the exercise of authority, control, and shared decision-making (planning, monitoring, and enforcement) over the management of data assets' (page 77 in the copy checked). (verified: DAMA-DMBOK2, checked in the printed book by the course owner, 7 November 2026.)
- Earlier summaries quoted the definition without 'shared decision-making' and gave page 67. (search-only: Government of Canada GCcollab wiki

'Data Governance' citing DMBOK2, and Perficient (2012) citing the DAMA Dictionary, seen through search results, November 2026.)

E2-L2 A maturity baseline you can defend

Concept

A **maturity baseline** records how well each knowledge area is run today, so you can set targets and show progress. DMBOK2 describes a data management maturity assessment. Sources differ on the exact level names, so agree one scale with your stakeholders and write it down. A common version runs from 0 to 5:

- **0** no capability
- **1** initial: ad hoc, depends on individuals
- **2** repeatable: some process, applied unevenly
- **3** defined: a documented standard, followed across teams
- **4** managed: measured, with targets and reviews
- **5** optimised: improved continuously from the measures

Each level builds on the last.

Score a **grid**, not a single number: knowledge areas down the side, talent domains across the top. A talent platform has six domains: workforce and organisation, recruitment, learning, performance, mobility and skills. Data quality can be at 3 for workforce data and at 1 for skills.

Three rules make a baseline you can defend.

1. **Evidence for every score.** A score without a document, a metric or a log is an opinion. "Level 3: quality rules documented in DQ-STD-02 and run nightly" survives a challenge.
2. **Report the weakest area, not the mean.** An average of 3 can hide a 0 in data security. One weak area can sink a domain.
3. **Integers only.** A level is a stage you have reached. A score of 2.5 says you have not agreed which stage you are at.

The baseline is a snapshot. Rescore at fixed intervals with the same scale, so changes mean progress, not a new yardstick.

Why it matters

A firm reported its talent data maturity as 3.1 out of 5 to its board and won budget for an AI pilot. The pilot stalled in week two: nobody owned access to

performance data, which scored 0 for data security in the performance domain. The average had hidden it. A grid reporting the weakest area per domain would have put security ahead of the pilot.

Worked example: weak code

```
# Maturity baseline, talent data
overall: 3.1
data_security: 2.5
evidence: workshop with the HR leadership team
```

1. **Line 2.** One mean for the whole platform hides the weakest area.
2. **Line 3.** A fractional level means the stage was never agreed.
3. **Line 4.** Opinions, not artefacts. Nothing an auditor can check.

Worked example: strong code

```
# Maturity baseline, talent data, scale DMMA-0-5 v1
performance:
  data_security: {score: 0, evidence: "no access model; analysts read raw reviews"}
  data_quality: {score: 2, evidence: "rules in DQ-PERF-01, run by hand monthly"}
  weakest: {area: data_security, score: 0}
workforce:
  data_security: {score: 3, evidence: "role model SEC-STD-01, quarterly access review log"}
  weakest: {area: metadata, score: 1}
```

1. **Line 1.** The scale is named and versioned, so rescoring uses the same yardstick.
2. **Line 3.** Every score cites evidence.
3. **Line 5.** Each domain reports its weakest area, not its average.

Score a grid of knowledge areas by talent domain, in whole levels, with evidence for each score, and report the weakest area per domain.

Recap card

- **A common 0 to 5 maturity scale** 0 none, 1 initial, 2 repeatable, 3 defined, 4 managed, 5 optimised. Agree and version the names with stakeholders.
- **The baseline grid** Knowledge areas by talent domain: workforce, recruitment, learning, performance, mobility, skills.
- **Summarise a domain by** Its weakest area and score. A mean hides gaps.

- **A defensible score** A whole level with cited evidence: a document, a metric or a log.

Practice

Exercise 1. Multiple choice (level 1)

Data quality rules for the learning domain are documented in a standard and followed by every team, but nobody measures them yet. Which level fits, on the 0 to 5 scale in this lesson?

- a) 1 initial
- b) 3 defined
- c) 4 managed
- d) 5 optimised

Exercise 2. Multiple choice (level 2)

The performance domain scores 4, 4, 3, 4 and 0 across five knowledge areas. What should the baseline report for the domain?

- a) 3, the mean
- b) 4, the most common score
- c) 0, with the area that scored it
- d) Nothing until every area reaches 3

Why?

- r1) One weak area can sink a domain, and a mean hides it.
- r2) The lowest score is always data security.

Exercise 3. Put in order (level 2)

Put the steps of building a maturity baseline in order.

- Agree and version the scale with stakeholders
- Score each cell in whole levels, citing evidence
- Lay out the grid: knowledge areas by talent domain
- Report the weakest area per domain
- Rescore at a fixed interval on the same scale

Exercise 4. Write the function (level 3)

Write `weakest_by_domain(scores: dict[str, dict[str, int]]) -> dict[str, tuple[str, int]]`. `scores` maps each talent domain to a dict of knowledge

area to score. Return, for each domain, the weakest area and its score. When two areas tie, pick the one that comes first alphabetically.

Raise `ValueError` if any score is not a whole number from 0 to 5, or if a domain has no scores. A `bool` does not count as a whole number.

What you need to know.

`isinstance(value, int)` checks a type. In Python, `True` is also an `int`, so check for `bool` first:

```
isinstance(3, int)       # True
isinstance(2.5, int)     # False
isinstance(True, bool)   # True, and isinstance(True, int) is True too
```

`min` takes a `key` function. A tuple key compares item by item: `min([("b", 1), ("a", 1)], key=lambda p: (p[1], p[0]))` returns `("a", 1)`.

Your code must pass these checks:

- Return the lowest-scoring area and its score for each domain.
- When areas tie, pick the one that comes first alphabetically.
- Raise ValueError for a score outside 0 to 5, a fraction, a bool, or a domain with no scores.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# Module constant.
MIN_LEVEL = ...

# Module constant.
MAX_LEVEL = ...

# The weakest knowledge area and its score for each talent domain.
def weakest_by_domain(
    scores: dict[str, dict[str, int]],
) -> dict[str, tuple[str, int]]: ...
```

Starter code:

```
def weakest_by_domain(scores):
    return {domain: min(areas.items()) for domain, areas in
    scores.items()}
```

Exercise 5. Architecture design (level 4)

Plan how you present the first talent data maturity baseline to HR leadership.

Options: A grid of areas by domain, with the weakest area per domain highlighted, One overall maturity score out of 5.

1. Headline

2. Evidence
3. What the baseline leads to

Sources

- DMBOK2 chapter 15, Data Management Maturity Assessment, uses six levels: 0 no capability, 1 initial or ad hoc, 2 repeatable, 3 defined, 4 managed, 5 optimised. It starts at 0, unlike CMM models that start at 1. (verified: DAMA-DMBOK2, checked in the printed book by the course owner, 7 November 2026.)
- The six talent domains (workforce and organisation, recruitment, learning, performance, mobility, skills) come from the role brief, not from DAMA. (verified: content/roles/ey-talent.yaml, the job description in the brief.)

E2-L3 Governance at the hub, decision rights, policies and escalation

Concept

Governance and management are different jobs. **Data governance** decides and oversees: who may decide what, which rules apply, and whether they are followed. **Data management** does the work: builds the pipelines, runs the quality checks, grants the access. DMBOK2 frames governance as setting decision rights over data. A platform team that both writes the rules and marks its own work has no oversight.

Start with **decision rights**. For each kind of decision, name who decides:

- what a term means, such as "active employee" or "regretted leaver"
- who may see a field, such as salary or a performance rating
- what quality threshold a dataset must meet before it is published
- whether a new use of data goes ahead

Then write the rules at three levels:

- A **policy** says what must be true, and why. "Access to performance data follows the principle of least privilege."
- A **standard** makes it measurable. "Ratings are masked for every role except HR business partners and the employee's own line chain."
- A **procedure** says how. "Request access through the form. The data owner approves within five working days."

Policies change rarely and need senior sign-off. Standards change when the platform does. Procedures change often.

Finally, an **escalation path**. Most issues end with a data steward. Those that cross domains, or set precedent, go to the data owner, then to a governance council. Each decision is written down in a decision log (lesson B18-L3), so the next person finds the reason, not only the rule.

GOV-02 in your EY role plan turns these rights into a RACI.

Why it matters

Two directors argued for a quarter over whether contractors counted in "headcount". The data team changed the dashboard each time one of them complained. Nobody had the right to decide, so the definition flipped four times and trust in every people report fell. A named decision owner and one log entry settled it in a week.

Worked example: weak code

```
# Governance, talent platform
rules: the data platform team decides and enforces everything
access_rule: be careful with sensitive data
disputes: raise in the weekly team meeting
```

1. **Line 2.** The same team writes the rules and marks its own work. No oversight.
2. **Line 3.** Not measurable. Nobody can test it.
3. **Line 4.** No owner, no record, so the same dispute comes back.

Worked example: strong code

```
# Governance, talent platform
decision_rights:
  definitions: {decides: data owner per domain, advises: data steward}
  access_to_performance_data: {decides: performance data owner}
policy: POL-07 least privilege for performance data
standard: STD-07 ratings masked except HR business partners and line chain
procedure: PRC-07 request form, owner approves within 5 working days
escalation: [data steward, data owner, governance council]
decisions: logged in DEC-LOG with the reason and the date
```

1. **Line 3.** One named decider per kind of decision.
2. **Line 6.** The standard makes the policy testable.
3. **Line 8.** A fixed path, so disputes end with a decision.

Separate deciding from doing. Name a decider for each kind of decision, write rules as policy, standard and procedure, and log each decision with its reason.

Recap card

- **Governance against management** Governance decides and oversees. Management does the work.
- **Decision rights to name first** Definitions, access to sensitive fields, quality thresholds, and new uses of data.
- **Policy, standard, procedure** Policy: what and why. Standard: measurable. Procedure: how. Each changes at its own pace.
- **Escalation path** Data steward, data owner, governance council. Log every decision with its reason.

Practice

Exercise 1. Multiple choice (level 1)

Which of these is a data governance activity rather than a data management one?

- a) Running the nightly quality checks
- b) Deciding who may approve access to salary data
- c) Building the silver layer for learning records
- d) Granting a role in a workspace

Exercise 2. Multiple choice (level 2)

Which statement is a standard, not a policy or a procedure?

- a) Access to performance data follows least privilege.
- b) Ratings are masked for every role except HR business partners and the line chain.
- c) Request access through the form, and the owner approves within five working days.
- d) Be careful with sensitive data.

Why?

- r1) A standard makes a policy measurable, so you can test whether it holds.
- r2) A standard says who signs it off.

Exercise 3. Fill the gap (level 2)

Complete the three levels of rules.

```
_____(1): what must be true, and why. Changes rarely, senior sign-off.
_____(2): makes it measurable. Changes when the platform does.
```

```
3 _____(3): how to do it. Changes often.
```

Exercise 4. Put in order (level 3)

A dispute over what "regretted leaver" means affects two domains. Put the escalation steps in order.

- The data owners of both domains try to agree
- Update the glossary entry and tell the report owners
- Record the decision and its reason in the decision log
- The data steward gathers the definitions in use and their impact
- Without agreement, the governance council decides

Exercise 5. Architecture design (level 4)

Set up governance for the talent platform's first domain, performance data.

Options: The performance data owner, a named HR leader, advised by a steward, The data platform team, because it builds the tables.

1. Who decides what a performance rating means
2. The access rule
3. Disputes

Sources

- DMBOK2 chapter 3 separates governance, a formal system of decision rights over data with an escalation path for issues, from data management, which carries out the work. A Data Governance Council is the highest functional authority for policy and data disputes. (verified: DAMA-DMBOK2, checked in the printed book by the course owner, 7 November 2026.)
- Policy, standard and procedure as three levels of rules, and the steward, owner, council escalation path, are common governance practice, not quotations from DMBOK2. (unverified: General practice. Not attributed to a specific DMBOK2 passage.)

E2-L4 People master data, match rules and survivorship

Concept

Lesson E2-L1 named the problem: one person, two employee IDs. Master data management fixes it in two steps, and each step needs a written rule that the master data owner signs off.

Match: which records are the same person?

- A **deterministic** rule matches on exact keys, such as national insurance number plus date of birth. It is easy to explain and misses typos.
- A **probabilistic** rule scores similarity across fields, such as name, date of birth and email, and matches above a threshold. It catches more and makes some false matches.

Run both in bands. Above a high score, merge automatically. Below a low score, keep the records apart. In between, send the pair to a **data steward** queue. A false merge mixes two people's salaries and appraisals, which is worse than a missed match.

Survivorship: which value wins? Once records match, the **golden record** takes each field from one of them. Write a rule per field:

- **Source priority**: the HR system wins for legal name and grade, the learning platform for course history.
- **Most recent**: for a home address, the latest update wins.
- **Most complete**: a value beats a missing one. A blank must never overwrite a value.

DMBOK2 names two patterns. **Match-merge** builds one physical record. **Match-link** only links source records to a global ID, which is easier to reverse.

Either way, keep a **cross-reference** from the golden ID to every source ID it absorbed. Then a later delivery from any source still finds its person, and an unmerge stays possible when a steward finds a false match.

The rules are data, kept in a versioned file the owner signs off, not logic buried in a notebook.

Why it matters

A firm's master data job merged two employees called Daniel Hughes, born in the same year, because its rule matched on name and birth year only. For three weeks one Daniel saw the other's performance rating in the self-service portal. The firm reported the breach to the regulator, and rewrote the rule to need a national insurance number match before any automatic merge.

Worked example: weak code

```
# Person matching, talent platform
match: same first name, surname and birth year
merge: automatic
```

```
❸ survivorship: the last record loaded wins every field
```

1. **Line 2.** Two different people share these often in a large firm.
2. **Line 3.** No steward review for uncertain pairs, so false merges go live.
3. **Line 4.** A blank or stale field from the latest load can overwrite a correct value.

Worked example: strong code

```
 1 # Person matching, talent platform, version 3, signed off by the people
     master data owner
 2 match:
❶   auto_merge: national insurance number and date of birth agree
❷   steward_review: name, date of birth and email score 0.80 to 0.95
 5   keep_apart: score below 0.80
 6 survivorship:
❸   legal_name: {rule: source_priority, order: [hr_system, payroll,
     learning]}
 8   grade: {rule: source_priority, order: [hr_system, payroll]}
 9   home_address: {rule: most_recent}
10   any_field: never overwrite a value with a blank
❹ cross_reference: golden ID to every source ID, kept for unmerge
```

1. **Line 3.** Automatic merges only on a deterministic key.
2. **Line 4.** The uncertain band goes to a person.
3. **Line 7.** A rule per field, with the trusted source first.
4. **Line 11.** Source IDs stay findable, and a false merge can be undone.

Match in bands, with only deterministic keys merging automatically. Choose each field's value by a written rule, never let a blank win, and keep the cross-reference.

Recap card

- **Deterministic or probabilistic matching** Deterministic: exact keys, easy to explain, misses typos. Probabilistic: similarity score, catches more, makes false matches.
- **Match bands** Merge above a high score, keep apart below a low one, and send the middle band to a data steward.
- **Common survivorship rules** Source priority, most recent, most complete. A blank never overwrites a value.
- **Why keep a cross-reference?** Later deliveries find their person by source ID, and a false merge can be undone.

Practice

Exercise 1. Multiple choice (level 1)

What does a survivorship rule decide?

- a) Which value each field of the golden record takes
- b) Which records belong to the same person
- c) Who may see the golden record
- d) How long the source records are kept

Exercise 2. Multiple choice (level 2)

A probabilistic match scores 0.87 for two employee records. Your bands are: merge above 0.95, keep apart below 0.80. What happens?

- a) The pair goes to the data steward queue
- b) The records merge automatically
- c) The records stay apart and nobody reviews them
- d) The newest record replaces the older one

Why?

- r1) A score between the bands is uncertain, and a false merge mixes two people's data.
- r2) Stewards review every match, whatever its score.

Exercise 3. Fill the gap (level 2)

Complete the survivorship rules.

```
legal_name:    source _____(1), the HR system first
home_address:  most _____(2) update wins
any field:     never overwrite a value with a _____(3)
```

Exercise 4. Write the function (level 3)

Write `survive(records: list[dict], priority: list[str]) -> dict`. Each record has a `"source"` key and field values, some of which may be `None`. `priority` lists sources, most trusted first.

Return the golden record: for every field other than `"source"`, take the value from the most trusted source whose value is not `None`. Leave out a field that is `None` in every record. Raise `ValueError` if a record's source is not in `priority`.

What you need to know.

`list.index(item)` gives an item's position: `["a", "b", "c"].index("b")` is `1`. It raises `ValueError` for a missing item.

`sorted` takes a `key` function and returns a new list:

```
ranks = ["gold", "silver", "bronze"]
medals = [{"m": "bronze"}, {"m": "gold"}]
sorted(medals, key=lambda d: ranks.index(d["m"]))   # gold first
```

Test for a missing value with `value is None`, so `0` and `""` still count as values.

Your code must pass these checks:

- Take each field from the most trusted source, whatever order the records arrive in.
- A None from a trusted source must not beat a real value from a less trusted one.
- 0 is a value. Test for a missing value with `is None`.
- Leave out a field that is None in every record.
- Raise ValueError for a source that is not in the priority list.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# The golden record built from matched source records.
def survive(
    records: list[dict],
    priority: list[str],
) -> dict: ...
```

Starter code:

```
def survive(records, priority):
    golden = {}
    for record in records:
        golden.update(record)
    golden.pop("source", None)
    return golden
```

Exercise 5. Architecture design (level 4)

Set the master data rules for the person entity on a talent platform with three sources: the HR system, payroll and the learning platform.

Options: Only when national insurance number and date of birth agree, When name and birth year agree.

1. Automatic merge
2. Uncertain pairs
3. Source IDs after a merge

Sources

- DMBOK2 chapter 10 describes deterministic and probabilistic matching, referring candidate duplicates to data stewards, match-merge and match-link, survivorship rules (most trusted source, most recent, most complete), golden records, and cross-reference management between source IDs and a global ID. (verified: DAMA-DMBOK2, checked in the printed book by the course owner, 7 November 2026.)
- Automatic merging in score bands, with only deterministic keys merging automatically, is this lesson's recommended practice. (unverified: General master data management practice, not a DMBOK2 quotation.)

E2-L5 A RACI and a business glossary for talent data

Concept

Lesson E2-L3 named who decides. A **RACI** turns that into a table people can check, and a **business glossary** records what they decided.

RACI. Rows are activities, columns are roles, and each cell holds one letter:

- **R, responsible**: does the work. At least one per activity.
- **A, accountable**: owns the outcome and signs it off. **Exactly one** per activity.
- **C, consulted**: asked before the decision, a two-way conversation.
- **I, informed**: told after it, one way.

Two common failures: an activity with two As, so each waits for the other, and one with no A, so nobody signs off. Name roles, not people, so the table survives a reorganisation.

Business glossary. One entry per business term, such as "active employee" or "regretted leaver". Each entry holds:

- the **term** and a plain **definition**;
- the **calculation rule**, where it is a measure, such as which contract types count;
- the **owner** (the A for its definition) and the **steward** who maintains it;
- the **system of record** that holds the data;
- **related terms** and the ones it must not be confused with;
- a **status** (draft or approved), a version and the date approved.

A definition changes only through the escalation path in lesson E2-L3, and every change gets a new version, so a report can say which definition it used.

DMBOK2 places the business glossary in **metadata management**. Start with the 15 terms that appear most in people reports, not the whole vocabulary.

Why it matters

Two HR directors each believed they owned the definition of "headcount", and the RACI listed both as accountable. Each approved a different version for their own reports, so the board pack showed two headcounts 4% apart. Making one of them accountable, and recording the approved definition in the glossary with a version, ended it.

Worked example: weak code

```
1  # RACI, talent data
2  define headcount: {HR director: A, People analytics lead: A, Data
     steward: R}
3  grant access to ratings: {Platform team: R}
4  glossary: a shared page where anyone adds terms
```

1. **Line 2.** Two accountable roles. Each will approve their own definition.
2. **Line 3.** Nobody is accountable for who sees performance ratings.
3. **Line 4.** No owner, no status, no version. Nobody knows which definition is approved.

Worked example: strong code

```
1  # RACI, talent data
2  define headcount: {Workforce data owner: A, Data steward: R, Finance: C,
     Report owners: I}
3  grant access to ratings: {Performance data owner: A, Platform team: R,
     DPO: C}
4  # Glossary entry
5  term: Headcount
6  definition: People with an active employment contract on the reporting
     date
7  rule:
     count contracts of type permanent or fixed-term; exclude contractors
     and agency staff
8  owner: Workforce data owner
9  steward: Workforce data steward
10 system_of_record: HR system, employment table
11 not_to_confuse_with: [FTE, contractor count]
```

```
❸ status: approved, version 2, 2026-11-07
```

1. **Line 2.** One A, at least one R, and the people consulted and informed are named.
2. **Line 7.** The calculation rule settles the dispute a definition alone leaves open.
3. **Line 12.** A version and a date let a report say which definition it used.

Give every activity exactly one A and at least one R, name roles rather than people, and keep each glossary term with a rule, an owner, a steward, a system of record and a versioned status.

Recap card

- **RACI letters** R does the work, A owns and signs off (exactly one), C is asked before, I is told after.
- **Two RACI failures** Two accountable roles, so each waits or approves their own; no accountable role, so nobody signs off.
- **Glossary entry fields** Term, definition, calculation rule, owner, steward, system of record, related terms, status with version and date.
- **Where to start a glossary** The 15 terms used most in people reports, not the whole vocabulary.

Practice

Exercise 1. Multiple choice (level 1)

How many accountable roles should each activity in a RACI have?

- a) Exactly one
- b) At least one
- c) One per team involved
- d) None, if someone is responsible

Exercise 2. Multiple choice (level 2)

The data protection officer must give a view before ratings access is granted. Which letter fits the DPO?

- a) C
- b) I
- c) A
- d) R

Why?

- r1) Consulted means asked before the decision, in a two-way exchange.

- r2) Consulted means told after the decision.

Exercise 3. Fill the gap (level 2)

Complete the glossary entry fields.

```
term, definition, calculation _____(1)
_____(2) (accountable for the definition) and steward
system of _____(3)
status, version and date approved
```

Exercise 4. Write the function (level 3)

Write `raci_problems(raci: dict[str, dict[str, str]]) -> list[str]`. `raci` maps each activity to a dict of role to letter.

Return a sorted list of problems, using exactly these messages:

- `"<activity>: no accountable role"` when no role has `"A"`;
- `"<activity>: <n> accountable roles"` when more than one has `"A"`;
- `"<activity>: no responsible role"` when no role has `"R"`;
- `"<activity>: unknown letter <x> for <role>"` for any letter other than R, A, C or I.

Return an empty list when every activity is sound.

What you need to know.

`list.count(x)` counts how many items equal `x`:

```
grades = ["pass", "fail", "pass"]
grades.count("pass")   # 2
```

`dict.values()` gives the values of a dict, and `list(d.values())` turns them into a list.

Your code must pass these checks:

- A sound activity has no problems.
- Report a missing accountable role, and more than one, with the exact messages.
- Report an activity with no responsible role.
- Report any letter other than R, A, C or I.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# Module constant.
VALID_LETTERS = ...

# Problems in a RACI: missing or duplicate accountable roles, no
    responsible role, bad letters.
```

```python
def raci_problems(
    raci: dict[str, dict[str, str]],
) -> list[str]: ...
```

Starter code:

```python
def raci_problems(raci):
    return []
```

Exercise 5. Architecture design (level 4)

Start the glossary and RACI for the talent platform's first month.

Options: The 15 terms used most in people reports, Every term in the HR system, at once.

1. Which terms first
2. RACI columns
3. Changing a definition

Sources

- DMBOK2 places the business glossary within metadata management. (search-only: DMBOK2 chapter 12 as summarised in secondary sources; not part of the extracts checked in the book.)
- RACI conventions (exactly one accountable, at least one responsible, consulted before, informed after) and the glossary fields listed are common practice. (unverified: General governance practice, not a quotation from a standard.)

E3 Cross-border transfers and works councils

Roadmap: EY Talent Data Strategy role; Current work. Restricted transfers and the three-step test, choosing a transfer mechanism with a risk assessment, and consulting works councils before people analytics or AI.

E3-L1 Restricted transfers, when people data leaves the UK

Concept

Talent data rarely stays in one country. A shared service centre runs payroll, a vendor hosts the learning platform, a group company abroad builds the dashboards. UK GDPR Chapter V controls these flows as **restricted transfers**.

Since the ICO's January 2026 guidance, a **three-step test** tells you whether a flow is restricted. Answer yes to all three and it is:

1. Does UK GDPR apply to your processing of the data?
2. Do you **initiate** the transfer, by sending the data or by making it available to someone outside the UK?
3. Is the receiver a **separate legal person**, such as another company in your group?

A UK branch sending data to its own overseas head office fails step 3, so it is not restricted. A UK company sending data to a sister company in India is restricted, even inside one group.

A restricted transfer needs one of three routes:

- **Adequacy regulations**: UK law approves the destination. Transfers to the EEA countries are treated as approved.
- **Appropriate safeguards**: a contract such as the International Data Transfer Agreement (**IDTA**), plus a check that protection is "not materially lower" than in the UK. Lesson E3-L2 covers how to choose.
- **Exceptions**: narrow, for occasional transfers. Explicit consent rarely works for employees, for the reason lesson E1-L2 gives.

The **Data (Use and Access) Act 2025** set the "not materially lower" standard. It took effect on 5 February 2026.

The direction matters. The EU's adequacy decision for the UK, renewed to 27 December 2031, covers data flowing into the UK from the EU. It says nothing about data you send out.

Why it matters

A UK HR team gave a sister company in another country read access to a performance dashboard "so they could help". Nobody saw it as a transfer, because no file moved. An audit found 9,000 employee records available to a separate legal entity with no contract in place. Access was withdrawn for three months while legal put an agreement in place.

Worked example: weak code

```
1  # Data flows, talent platform
2  - flow: performance dashboard shared with group analytics team abroad
1    transfer: no, nothing is copied
4  - flow: payroll extract to UK branch office in Dublin
2    transfer: no, same company
```

1. **Line 3.** Making data available abroad is a transfer. Access counts, not only copies.
2. **Line 5.** Dublin is outside the UK. Ask step 3 explicitly: is the receiver the same legal person?

Worked example: strong code

```
1  # Data flows, talent platform
2  - flow: performance dashboard shared with group analytics team abroad
3    uk_gdpr_applies: yes
1    initiated_by_us: yes, we grant access
5    separate_legal_person: yes, a sister company
2    restricted: yes
7    route: to be chosen, see E3-L2
8  - flow: payroll extract to our own branch office in Dublin
3    separate_legal_person: no, same company
10   restricted: no
```

1. **Line 4.** Granting access initiates the transfer.
2. **Line 6.** Three yeses make a restricted transfer. Record each answer, not only the verdict.
3. **Line 9.** A branch is the same legal person, so step 3 fails.

Run the three-step test on every flow, access included. Record each answer, then pick a route: adequacy, safeguards or a narrow exception.

Recap card

- **The ICO's three-step test** UK GDPR applies, you initiate a transfer outside the UK, and the receiver is a separate legal person. Three yeses make it restricted.
- **Access or copies?** Making data available abroad initiates a transfer. No copy is needed.
- **Three routes for a restricted transfer** Adequacy regulations, appropriate safeguards such as the IDTA, or a narrow exception.
- **EU adequacy for the UK** Renewed to 27 December 2031. It covers data coming into the UK, not data you send out.

Practice

Exercise 1. Multiple choice (level 1)

Which flow is a restricted transfer under UK GDPR?

- a) A UK company sends appraisal data to its sister company in India
- b) A UK company sends appraisal data to its own branch office in India
- c) A UK company moves appraisal data between two UK data centres
- d) A UK company deletes appraisal data after the retention period

Exercise 2. Multiple choice (level 2)

A UK team gives a group company in Singapore read access to a talent dashboard. No file is copied. Is this a restricted transfer?

- a) Yes
- b) No

Why?

- r1) Making data available to a separate legal person abroad initiates a transfer, even without a copy.
- r2) Any data viewed from abroad is a transfer, whoever the viewer works for.

Exercise 3. Fill the gap (level 2)

Complete the three routes for a restricted transfer.

```
1. _____(1) regulations: the UK has recognised the destination.
2. Appropriate _____(2), such as the IDTA, with protection not materially
   lower than in the UK.
3. _____(3), narrow and for occasional transfers.
```

Exercise 4. Put in order (level 3)

Put the steps for a new talent data flow in order.

- Check that UK GDPR applies to the processing
- Record each answer and the route in the data flow register
- Choose a route: adequacy, safeguards or an exception
- Check whether you send the data or make it available outside the UK
- Check whether the receiver is a separate legal person

Exercise 5. Architecture design (level 4)

A group analytics team abroad asks for the UK performance data. Decide how to handle the request.

Options: Run the three-step test on the flow, access included, Check only whether files will be copied abroad.

1. First step
2. The receiver
3. If the transfer is restricted

Sources

- The ICO updated its international transfers guidance on 15 January 2026, with a three-step test: UK GDPR applies, the sender initiates a transfer outside the UK, and the receiver is a separate legal person. A UK branch sending data to its overseas head office is not a restricted transfer. (search-only: Commentary by Kennedys, Freshfields, McDermott Will & Emery and White & Case on the ICO guidance, seen through search results, November 2026. ico.org.uk was not reachable from the build environment.)
- Section 85 and Schedule 7 of the Data (Use and Access) Act 2025 replaced Article 45 with Articles 45A and 45B and set the data protection test: protection 'not materially lower' than under UK GDPR. In force from 5 February 2026 (SI 2026/82). (verified: https://www.legislation.gov.uk/ukpga/2025/18/schedule/7 and https://www.legislation.gov.uk/ukpga/2025/18/section/85, checked 7 November 2026.)
- Transfers to an EEA state are treated as approved by regulations under Article 45A (DPA 2018 Schedule 21, paragraphs 4 and 5). (verified: https://www.legislation.gov.uk/ukpga/2018/12/schedule/21/paragraph/5, checked 7 November 2026.)

- The European Commission renewed its adequacy decisions for the UK on 19 December 2025, until 27 December 2031. (search-only: Hunton, Freeths, RPC and Computer Weekly reports, seen through search results, November 2026.)

E3-L2 Choosing a transfer mechanism and the transfer risk assessment

Concept

Once a flow is a restricted transfer, pick its route in a fixed order.

1. Adequacy first. If UK adequacy regulations cover the destination, the transfer can go ahead with no extra contract. The UK covers the EEA countries, among others. For the United States, the **UK Extension to the EU-US Data Privacy Framework**, the "data bridge", covers only US organisations certified under it.

2. Appropriate safeguards next. Three are common for talent data:

- the **IDTA**, the UK's own contract;
- the **UK Addendum**, which extends the EU standard contractual clauses to UK data. It suits a group that already signs the EU clauses;
- **binding corporate rules**, approved rules for transfers inside a group.

A contract alone is not enough. With a safeguard you complete a **transfer risk assessment** (TRA). The exporter, acting reasonably and proportionately, must judge that protection after the transfer is "not materially lower" than in the UK. UK law now calls this the **data protection test**. If the TRA fails, add protections, such as pseudonymised data or keys kept in the UK, or do not transfer.

3. Exceptions last. Article 49 lists them. Its last-resort exception covers only transfers that are not repetitive, so never a nightly pipeline.

Record "not yet assessed" as its own state. A TRA that is missing is not a TRA that passed, and it is not one that failed. In code, keep `None` apart from `False`. Lesson E1-L3 made the same point about missing register fields.

Why it matters

A firm signed the IDTA with its offshore analytics vendor and filed it. Two years later a regulator asked for the risk assessment behind it. There was none. The contract was valid, but the firm could not show the transfer met the test, and it had to pause the feed until a TRA was done.

Worked example: weak code

```
1  def can_transfer(adequate, safeguard, tra_passed):
2      if adequate or safeguard:
3          return True
4      return False
```

1. **Line 1.** A yes or no hides which route applied, so the register cannot record it.
2. **Line 2.** A signed safeguard alone passes. The TRA result is never read.

Worked example: strong code

```
1  SAFEGUARDS = frozenset({"IDTA", "Addendum", "BCR"})
2
3
4  def transfer_route(adequate: bool, safeguard: str | None, tra_passed:
       bool | None) -> str:
5      """The route for a restricted transfer: adequacy, safeguards or
       stop."""
1      if adequate:
7          return "adequacy"
8      if safeguard is None:
9          return "stop"
10     if safeguard not in SAFEGUARDS:
11         raise ValueError(f"unknown safeguard: {safeguard}")
2      if tra_passed is None:
13         raise ValueError("complete a transfer risk assessment first")
3      return "safeguards" if tra_passed else "stop"
```

1. **Line 6.** Adequacy comes first and needs no TRA.
2. **Line 12.** Not yet assessed is its own state. It fails loudly instead of passing quietly.
3. **Line 14.** A failed TRA stops the transfer until protections are added.

Adequacy first, then a safeguard with a TRA that passes, then a narrow exception. Keep "not assessed" apart from "failed".

Recap card

- **Order of routes** Adequacy first, then a safeguard with a transfer risk assessment, then a narrow exception.
- **Common safeguards for talent data** The IDTA, the UK Addendum to the EU standard contractual clauses, and binding corporate rules.
- **The data protection test** With a safeguard, the exporter judges, reasonably and proportionately, that protection is not materially lower than in the UK.
- **Missing or failed?** A missing assessment is work not done. Keep `None` apart from `False` in code.

Practice

Exercise 1. Multiple choice (level 1)

Talent data goes to a company in a country covered by UK adequacy regulations. What else does the transfer need?

- a) Nothing more for the transfer itself
- b) An IDTA and a transfer risk assessment
- c) Explicit consent from each employee
- d) Approval from the ICO

Exercise 2. Multiple choice (level 2)

A group already signs the EU standard contractual clauses for its EU offices. Which safeguard fits its UK transfers best?

- a) The UK Addendum
- b) Explicit consent
- c) No safeguard, because the EU clauses cover UK data
- d) An exception for each transfer

Why?

- r1) The Addendum extends the EU clauses the group already uses to UK data.
- r2) The Addendum removes the need for a transfer risk assessment.

Exercise 3. Write the function (level 3)

Write `transfer_route(adequate: bool, safeguard: str | None, tra_passed: bool | None) -> str`.

- If `adequate` is true, return `"adequacy"`.
- Otherwise, if `safeguard` is `None`, return `"stop"`.
- If `safeguard` is not one of `"IDTA"`, `"Addendum"` or `"BCR"`, raise `ValueError`.
- If `tra_passed` is `None`, raise `ValueError`: the assessment is missing.
- Return `"safeguards"` if `tra_passed` is true, otherwise `"stop"`.

What you need to know.

`x is None` is true only for `None`. A falsy test such as `not x` is also true for `False`, `0` and `""`, so it cannot tell "missing" from "failed":

```
score = 0
score is None   # False: a score of 0 exists
not score       # True: 0 is falsy
```

`frozenset` makes a fixed set. `in` checks membership: `"red" in frozenset({"red", "blue"})` is `True`.

Your code must pass these checks:

- Adequacy comes first, whatever the other arguments say.
- A known safeguard with a passed TRA returns "safeguards".
- No safeguard, or a failed TRA, returns "stop".
- Raise ValueError when the TRA is missing. Missing is not the same as failed.
- Raise ValueError for a safeguard that is not IDTA, Addendum or BCR.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```python
# Module constant.
SAFEGUARDS = ...

# The route for a restricted transfer.
def transfer_route(
    adequate: bool,
    safeguard: str | None,
    tra_passed: bool | None,
) -> str: ...
```

Starter code:

```python
def transfer_route(adequate, safeguard, tra_passed):
    if adequate or safeguard:
        return "adequacy"
    return "stop"
```

Exercise 4. Put in order (level 3)

Talent data will go to an analytics vendor in a country without UK adequacy. Put the steps in order.

- Choose a safeguard, such as the IDTA
- Complete the transfer risk assessment against the data protection test
- Start the transfer and record the route
- Add protections the assessment calls for, such as pseudonymised identifiers
- Confirm no adequacy regulations cover the destination

Exercise 5. Architecture design (level 4)

Set the transfer policy for a nightly feed of performance ratings to a group company in a country without adequacy.

Options: Binding corporate rules or the IDTA between the two companies, An exception, because the group needs the data.

1. Mechanism
2. Assessment
3. Data sent

Sources

- Under Article 46(1A), as inserted by the Data (Use and Access) Act 2025, a transfer under appropriate safeguards needs the controller or processor, acting reasonably and proportionately, to consider that the data protection test is met. (verified: https://www.legislation.gov.uk/ukpga/2025/18/schedule/7, checked 7 November 2026.)
- With the IDTA or the UK Addendum, the exporter completes a transfer risk assessment. (search-only: Kennedys and Freshfields commentary on the ICO's January 2026 guidance, seen through search results, November 2026. ico.org.uk refused automated requests.)
- The UK Extension to the EU-US Data Privacy Framework, the 'data bridge', covers transfers only to US organisations on the Data Privacy Framework List as participating in the UK Extension. In force 12 October 2023. (verified: https://www.legislation.gov.uk/uksi/2023/1028/made, regulations 1(2) and 3(2)(a), checked 7 November 2026.)
- Binding corporate rules are an appropriate safeguard under Article 46(2)(b). Article 49's last-resort exception applies only if the transfer is not repetitive and concerns a limited number of data subjects. (verified: https://www.legislation.gov.uk/eur/2016/679/article/46 and https://www.legislation.gov.uk/eur/2016/679/article/49, checked 7 November 2026.)

E3-L3 Works councils and consultation before people analytics or AI

Concept

A people analytics tool can be lawful under UK GDPR and still stall at go-live, because nobody consulted the people it watches. Consultation duties come from employment law, not data protection law, and they differ by country.

United Kingdom. There is no general works council duty. Three sources still apply:

- The ICO's **monitoring workers** guidance (October 2023) expects you to consult workers and their representatives before monitoring, unless there is a good reason not to.
- UK GDPR **Article 35(9)** asks you, where appropriate, to seek the views of data subjects or their representatives in a DPIA.
- Recognised trade unions, collective agreements, or an agreement under the **Information and Consultation of Employees Regulations 2004** can set formal duties. In Great Britain, since 6 April 2020, 2% of employees, at least 15, can request such an agreement in a firm of 50 or more.

EU countries go further. A few examples:

- **Germany**: the works council has a **co-determination** right over technical systems designed to monitor behaviour or performance. Courts read "designed" as "able", so most HR software is in scope.
- **France**: the works council (CSE) must be consulted before new technology goes live. Courts have suspended AI tools deployed early.
- **Netherlands**: the works council has a **consent right** over personnel monitoring systems and rules on employee data.

The **EU AI Act** adds a duty for employers to inform workers' representatives before using a **high-risk AI system**, which includes most hiring and promotion tools. The 2026 amendments moved those high-risk obligations to 2 December 2027. National duties apply now.

Treat this as a map, not advice. Ask the employment lawyers in each country before go-live.

Why it matters

A firm rolled out an attrition-risk model to managers in France and Germany on the same day as the UK. In Germany, the works council had not agreed to it. In France, the works council had not given its opinion. Both sites switched the tool off within weeks. The UK pilot, where the team had consulted staff and recorded their views in the DPIA, kept running.

Worked example: weak code

```
❶ def needs_consultation(country):
```

```
❷     return country in ["DE", "FR", "NL"]
```

1. **Line 1.** A yes or no does not say which body to consult.
2. **Line 2.** Hard-coded law ignores what the tool does, and says the UK never needs consultation.

Worked example: strong code

```
❶ CONSULTATION_RULES = {
2     "DE": {"body": "works council", "triggers": {"monitoring",
    "high_risk_ai"}},
3     "FR": {"body": "CSE", "triggers": {"new_technology", "monitoring",
    "high_risk_ai"}},
4     "UK": {"body": "workers and representatives", "triggers":
    {"monitoring"}},
5 }
6
7
8 def consult_before_go_live(sites: list[str], features: set[str]) ->
    list[tuple[str, str]]:
9     """Each site's body to consult, from rules the employment lawyers
    maintain."""
10     plan = []
11     for country in sorted(set(sites)):
12         rule = CONSULTATION_RULES.get(country)
❷         if rule is None:
14             raise ValueError(f"no consultation rule for
    {country}: ask the lawyers")
❸         if rule["triggers"] & features:
16             plan.append((country, rule["body"]))
17     return plan
```

1. **Line 1.** The rules are data the lawyers own. In production they load from a versioned file.
2. **Line 13.** An unknown country stops the plan. Silence would read as no duty.
3. **Line 15.** What the tool does decides the duty, not the country alone.

Consultation turns on what the tool does and where the people are. Keep the rules as data the lawyers own, and fail loudly on a country nobody has assessed.

Recap card

- **UK consultation sources** ICO monitoring workers guidance, Article 35(9) views in a DPIA, and any union or ICE agreement.
- **Works council rights over monitoring tools** Germany: co-determination. France: CSE consultation before new technology. Netherlands: consent right.

- **EU AI Act and employers** Inform workers' representatives before using a high-risk AI system. Those obligations now apply from 2 December 2027.
- **What decides a consultation duty?** What the tool does, and where the affected people work. Keep the rules as data the lawyers own.

Practice

Exercise 1. Multiple choice (level 1)

Where does a duty to consult works councils about a people analytics tool come from?

- a) Employment law in each country, alongside data protection law
- b) Only from UK GDPR
- c) Only from the EU AI Act
- d) From the software vendor's terms

Exercise 2. Multiple choice (level 2)

A UK employer with no recognised union plans to monitor how often staff open the learning platform. What should it do about consultation?

- a) Consult workers before monitoring, and record their views in the DPIA
- b) Nothing, because the UK has no works council law
- c) Ask each worker for consent instead
- d) Wait until a worker complains

Why?

- r1) ICO guidance expects consultation before monitoring, and Article 35(9) asks for data subjects' views where appropriate.
- r2) UK law gives every workforce a works council with a veto.

Exercise 3. Fill the gap (level 2)

Complete the right each works council holds over a monitoring tool.

```
Germany: works council _____(1) over systems able to monitor behaviour or
    performance.
France: the _____(2) must be consulted before new technology goes live.
Netherlands: works council _____(3) right over personnel monitoring
    systems.
```

Exercise 4. Write the function (level 3)

Write `consult_before_go_live(sites: list[str], features: set[str], rules: dict[str, dict]) -> list[tuple[str, str]]`.

`sites` lists the country codes where affected employees work, possibly with repeats. `features` names what the tool does, such as `"monitoring"`. `rules` maps a country code to `{"body": str, "triggers": set[str]}`.

Return `(country, body)` for each distinct country whose triggers share at least one feature with the tool, sorted by country. Raise `ValueError` for a country that has no rule.

What you need to know.

`&` on two sets gives the items in both. An empty set is falsy:

```
{"red", "blue"} & {"blue", "green"}   # {"blue"}
bool({"red"} & {"green"})             # False
```

`dict.get(key)` returns `None` for a missing key instead of raising: `{"a": 1}.get("b")` is `None`.

`sorted(set(items))` drops repeats and sorts: `sorted(set(["b", "a", "b"]))` is `["a", "b"]`.

Your code must pass these checks:

- List each country once, sorted by country code.
- Include a country only when its triggers share a feature with the tool.
- Raise ValueError for a country with no rule. Silence would read as no duty.
- A tool with no triggering features needs no consultation entry.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# The body to consult in each country before go-live.
def consult_before_go_live(
    sites: list[str],
    features: set[str],
    rules: dict[str, dict],
) -> list[tuple[str, str]]: ...
```

Starter code:

```
def consult_before_go_live(sites, features, rules):
    return [(c, rules[c]["body"]) for c in sites]
```

Exercise 5. Architecture design (level 4)

Plan go-live for an attrition-risk model used by managers in the UK, Germany and France.

Options: Before go-live in each country, with time for the works councils' process, After launch, once managers find it useful.

1. When to consult

2. Roll-out
3. Record

Sources

- The ICO published final guidance on monitoring workers on 3 October 2023. It expects employers to consult workers and their representatives before monitoring, unless there is a good reason not to. (search-only: Baker McKenzie, Cooley and HFW summaries of the ICO guidance, seen through search results, November 2026.)
- UK GDPR Article 35(9): where appropriate, the controller shall seek the views of data subjects or their representatives on the intended processing. (verified: https://www.legislation.gov.uk/eur/2016/679/article/35, checked 7 November 2026.)
- Since 6 April 2020, a request for information and consultation arrangements under the ICE Regulations 2004 needs 2% of employees, at least 15 and at most 2,500, in an undertaking with 50 or more employees. The Regulations cover Great Britain. (verified: https://www.legislation.gov.uk/uksi/2004/3426/regulation/7 and schedule 1, checked 7 November 2026.)
- Section 87(1) no. 6 BetrVG gives German works councils co-determination over the introduction and use of technical devices intended to monitor employees' behaviour or performance. (verified: https://www.gesetze-im-internet.de/betrvg/__87.html, checked 7 November 2026.)
- The Federal Labour Court reads section 87(1) no. 6 widely: a device objectively able to monitor is enough. (search-only: Luther, GÖRG and Rödl commentary, seen through search results, November 2026.)
- French courts (Nanterre, 14 February 2025; Créteil, 15 July 2025) suspended AI tools deployed before the CSE was consulted under article L2312-8 of the Code du travail. (search-only: CMS and CFDT reports of the rulings, seen through search results, November 2026.)
- Article 27(1)(k) and (l) of the Dutch Works Councils Act give the works council a consent right over rules on processing employee personal data and over personnel monitoring systems. (search-only: Rendement and Responsible AI Platform summaries, seen through search results, November 2026.)
- AI Act Article 26(7) requires deployers who are employers to inform workers' representatives and affected workers before using a high-risk AI system at the workplace. The Digital Omnibus on AI, Regulation (EU)

2026/1744, moved the Annex III high-risk obligations to 2 December 2027. (verified: Regulation (EU) 2024/1689 Article 26(7) and Regulation (EU) 2026/1744 of 8 July 2026 (OJ L, 24 July 2026), recital on dates of application, on eur-lex.europa.eu, checked 7 November 2026.)

Track E best-practice checklist

☐ Treat every talent attribute as personal data. Flag special category data, including what a model infers.

☐ Every use of personal data has a lawful basis. Every use of special category data also has an Article 9 condition.

☐ Employers rarely rely on consent. Record a legitimate interests assessment when you use legitimate interests.

☐ Keep an appropriate policy document for the employment and substantial public interest conditions.

☐ Screen every new use of people data for a DPIA. Large-scale special category data always needs one.

☐ Govern with a frame everyone shares. Map each knowledge area to the talent domains, with an owner.

☐ Score maturity with evidence, per knowledge area and domain. Never average a gap away.

☐ Run the three-step test on every flow that leaves the UK, access included. Adequacy first, then a safeguard with a transfer risk assessment.

☐ Consult works councils and workers before go-live wherever a tool monitors people. The rules differ by country.

☐ The legal team and the data protection officer decide on compliance. These lessons teach you to ask the right questions.

Appendix: solutions and answer keys

Attempt each exercise before you read its solution. Track D answer keys are here too.

E1-L1 Personal data, special category data and the two-part test

E1-L1 exercise 1

Hints. (1) There are nine special categories. (2) Think of what membership of an organisation can reveal about someone. (3) Trade union membership is on the list.

Answer. c) Trade union membership

Trade union membership is one of the nine special categories. The others are racial or ethnic origin, political opinions, religious or philosophical beliefs, genetic data, biometric data used to identify someone, health, sex life and sexual orientation.

Common wrong answers.

- `a`: Age is a protected characteristic under the Equality Act 2010, but it is not one of the nine special categories.
- `b`: Salary is personal data, and confidential, but it is not a special category.
- `d`: An address is personal data, not special category data.

E1-L1 exercise 2

Hints. (1) What does the model output say about each person? (2) Does inferring a category count as processing it? (3) The ICO treats inferred special category data as special category data.

Answer. b) Yes, because the model infers information about health Because: r1) Inferring a special category from other data counts as processing that category.

The ICO's guidance says that inferring health, ethnicity, beliefs or sexual orientation means you are processing special category data and need an Article 9 condition.

Common wrong answers.

- `a`: Inferences count. A prediction about health is health data.

- `c`: Producing the inference is processing, whether or not anyone sees it.
- `d`: Scale matters for whether you need a DPIA, not for whether data is special category.
- `b|r2`: Right answer, wrong reason. A plain count of days absent is not health data. The model's inference about illness is.

E1-L1 exercise 3

Hints. (1) One article applies to all personal data. (2) The other applies only to special categories. (3) Article 6, then Article 9.

Answer.

```
Part 1: a lawful basis under Article 6
Part 2: a condition under Article 9
```

Every use of personal data needs an Article 6 lawful basis. Special category data needs an Article 9 condition as well.

Common wrong answers.

- g1 = `9`; g2 = `6`: The other way round. Every use of personal data needs an Article 6 basis. Special category data also needs an Article 9 condition.

E1-L1 exercise 4

Hints. (1) Put the nine names in a frozenset at module level. (2) Handle biometric before the general check. (3) `field.get("use") == "identify"` is True only when the use is set to identify.

Answer.

```python
SPECIAL_CATEGORIES = frozenset(
    {
        "racial_or_ethnic_origin",
        "political_opinions",
        "religious_or_philosophical_beliefs",
        "trade_union_membership",
        "genetic",
        "biometric",
        "health",
        "sex_life",
        "sexual_orientation",
    }
)


def is_special_category(field: dict) -> bool:
    """True when an attribute is special category data under Article 9.

    Args:
        field: Register entry with a "category" and an optional "use".
```

```
21
22      Returns:
23          Whether the attribute needs an Article 9 condition.
24      """
25      category = field["category"]
26      if category == "biometric":
27          return field.get("use") == "identify"
28      return category in SPECIAL_CATEGORIES
```

A constant holds the list, and the one conditional category gets its own branch. Age and sex stay out: they belong to the Equality Act list.

E1-L1 exercise 5

Hints. (1) Do the two lists of sensitive attributes match? (2) Can a column name hide what a field holds? (3) Is an inference data?

Answer.

- Two fields, because the GDPR list and the Equality Act list overlap only in part.
- Classify by content: a free-text field can hold health data under any name.
- Inferred attributes are special category data, so they belong in the register with their own access rules.

Separate the two lists, classify by content, and register inferences, so access rules and DPIA screening start from the truth.

Common wrong answers.

- fields = `one`: A single flag cannot say whether an attribute needs an Article 9 condition or only a fairness check.
- basis = `name`: A column called absence_note held health data in this lesson's example.
- inferred = `skip`: Inferring a special category is processing it.

E1-L2 A lawful basis for each use of talent data

E1-L2 exercise 1

Hints. (1) What agreement does a salary come from? (2) The employment contract. (3) Contract.

Answer. b) Contract

Paying salary is necessary to perform the employment contract, so the contract basis fits.

Common wrong answers.

- `a`: The employee cannot refuse payroll, so consent would not be freely given. Payroll performs the contract.
- `c`: Vital interests protects someone's life. Salary payments do not.
- `d`: Public task covers official functions set out in law, not paying staff.

E1-L2 exercise 2

Hints. (1) Who holds the power in employment? (2) Can consent be freely given when refusing feels risky? (3) Look for another basis, such as legitimate interests.

Answer. b) Employers rarely rely on consent, because the power imbalance makes it hard to give freely Because: r1) A worker who fears refusing has no genuine choice, so consent is hard to show as freely given.

The ICO treats consent as rarely appropriate for employers, because a worker's choice is not genuinely free. Legitimate interests, with a recorded assessment, usually fits voluntary analytics.

Common wrong answers.

- `a`: Consent is the hardest basis to rely on for employees, and it can be withdrawn at any time.
- `c`: It is not banned. The ICO says it can work where refusing truly has no consequences, but that is rare.
- `d`: No lawful basis is required for a type of activity. You choose the one that fits the purpose.
- `b|r2`: Right answer, wrong reason. The problem is the imbalance of power, not an expiry date.

E1-L2 exercise 3

Hints. (1) What do you need before you can test necessity? (2) The balancing test weighs the interest you named against the person's. (3) The record comes last, before processing begins.

Answer.

1. Purpose: identify the legitimate interest
2. Necessity: show the processing serves it and nothing less intrusive would
3. Balancing: weigh the person's interests, rights and freedoms against yours
4. Record the outcome before processing starts

Purpose, necessity, balancing, then a written record before processing starts.

Common wrong answers.

- You cannot weigh an interest you have not named yet. Start with the purpose.
- Record the outcome once all three parts are done, before processing starts.

E1-L2 exercise 4

Hints. (1) Both principles come from Article 5. (2) One limits purposes, the other keeps data to a minimum. (3) `limitation`, then `minimisation`.

Answer.

```
1 Purpose limitation: a lawful basis covers the purposes you specified. A
    new purpose needs its own check.
2 Data minimisation: hold only the data each purpose needs.
```

Purpose limitation and data minimisation are Article 5 principles. Together they stop one dataset quietly serving every new idea.

Common wrong answers.

- g1 = `minimisation`; g2 = `limitation`: The other way round: purpose limitation, data minimisation.

E1-L2 exercise 5

Hints. (1) Which uses does the law require? (2) Which use is a new purpose? (3) A new purpose needs its own basis check.

Answer.

- Right-to-work checks are required by law, so legal obligation fits.
- Training records support the employment relationship. Record which basis you use and why.
- The attrition model is a new purpose. It needs its own basis check and assessment, and only the fields it uses.

Legal duties use legal obligation. Running the employment relationship uses contract or legitimate interests. A new analytics purpose gets its own assessment.

Common wrong answers.

- right_to_work = `consent`: The check is a legal duty. Consent would be misleading, because the worker cannot refuse.
- attrition = `inherit`: Purpose limitation: payroll's basis does not cover a new analytics purpose.

- attrition = `consent`: Consent rarely works for employees, and withdrawals would leave holes in the model.

E1-L3 Article 9 conditions, policy documents and DPIA screening in HR

E1-L3 exercise 1

Hints. (1) Monitoring equality is a substantial public interest. (2) Which Schedule 1 paragraph names equality? (3) Paragraph 8.

Answer. a) Article 9(2)(g) with Schedule 1 paragraph 8, equality of opportunity or treatment

Article 9(2)(g) with Schedule 1 paragraph 8 covers reviewing equality of opportunity or treatment between groups.

Common wrong answers.

- `b`: Paragraph 1 covers obligations and rights in employment law. Diversity monitoring uses the equality condition in paragraph 8.
- `c`: Consent is rarely appropriate for employees, and monitoring has its own condition.
- `d`: You process individual records before you aggregate them, so you need a condition.

E1-L3 exercise 2

Hints. (1) What does paragraph 8 allow you to do? (2) Is a shortlist a decision about a person? (3) Monitoring and decisions need separate data and separate conditions.

Answer. b) Paragraph 8 supports monitoring equality across groups, not decisions about one person Because: r1) The ICO says the equality condition cannot be relied on when processing is for decisions about a particular individual.

Keep equality monitoring data apart from decisions about individuals. Paragraph 8 does not cover them.

Common wrong answers.

- `a`: Purpose limitation: the data was collected for monitoring, under a condition that does not cover decisions.
- `c`: Racial or ethnic origin is a special category.
- `d`: Frequency is not the issue. The use is.

- `b|r2`: Right answer, wrong reason. Retention periods are set in your policy, but the problem here is using monitoring data for individual decisions.

E1-L3 exercise 3

Hints. (1) Part 1 of Schedule 1 starts with the employment condition. (2) APD stands for appropriate ... document. (3) Paragraph `1`, and `policy`.

Answer.

```
Article 9(2)(b) in the UK needs Schedule 1, Part 1, paragraph 1
and an appropriate policy document that names the condition and the
    retention rules.
```

The employment condition is Schedule 1, Part 1, paragraph 1, and it needs an appropriate policy document.

Common wrong answers.

- g1 = `8`: Paragraph 8 is equality of opportunity or treatment, a substantial public interest condition. The employment condition is paragraph 1.

E1-L3 exercise 4

Hints. (1) Loop over the entries once, appending messages as you go. (2) Check the basis, then the Article 9 condition, then the two documentation rules. (3) Only 9(2)(b) and 9(2)(g) need Schedule 1 and the policy document.

Answer.

```python
LAWFUL_BASES = frozenset(
    {
        "consent",
        "contract",
        "legal_obligation",
        "vital_interests",
        "public_task",
        "legitimate_interests",
    }
)
NEEDS_SCHEDULE_1 = frozenset({"9(2)(b)", "9(2)(g)"})


def check_register(entries: list[dict]) -> list[str]:
    """List the documentation gaps in a processing register.

    Args:
        entries: Register entries with lawful basis, Article 9 condition,
            Schedule 1 condition and policy document status.

    Returns:
        One message per problem, in register order.
```

```
    """
    problems: list[str] = []
    for entry in entries:
        name = entry["attribute"]
        if entry["lawful_basis"] not in LAWFUL_BASES:
            problems.append(f"{name}: no lawful basis")
        if entry["special"] and entry["condition"] is None:
            problems.append(f"{name}: no Article 9 condition")
        if entry["condition"] in NEEDS_SCHEDULE_1:
            if entry["schedule1"] is None:
                problems.append(f"{name}: no Schedule 1 condition")
            if not entry["apd"]:
                problems.append(f"{name}: no appropriate policy document")
    return problems
```

Encoding the register rules as a check means every new attribute is tested the same way, and the gaps show up before an auditor finds them.

E1-L3 exercise 5

Hints. (1) Count the risk factors: scale, special category data, significant effects. (2) What is a DPIA for, if not to shape the design? (3) What does Article 36 prior consultation mean?

Answer.

- Inferred health risk across 40,000 people is large-scale special category data, and ranking for promotion is profiling with significant effects. Both always need a DPIA.
- The DPIA comes before processing, so its findings can change the design, for example by dropping the health inference.
- A high risk you cannot reduce means consulting the ICO first.

Screen early, assess before processing, and consult the ICO when a high risk remains.

Common wrong answers.

- need = `not_needed`: Holding the data already changes nothing. A new use with these risk factors always needs a DPIA.
- when = `after`: A DPIA after the run cannot shape the design. It comes first.
- residual = `proceed`: An unmitigated high risk needs prior consultation with the ICO.

E1-L4 Writing the DPIA for a people model

E1-L4 exercise 1

Hints. (1) Article 35(7) is about risks to people. (2) Three options appear in the lesson's list of four. (3) The business case is not a DPIA part.

Answer. a) A return on investment calculation

Description, necessity and proportionality, risks, and measures. A business case belongs elsewhere.

Common wrong answers.

- `b`: The description is the first required part.
- `c`: Necessity and proportionality is the second required part.
- `d`: Measures are the fourth required part.

E1-L4 exercise 2

Hints. (1) Which rating triggers prior consultation? (2) Does every DPIA go to the ICO? (3) High residual risk means the ICO first.

Answer. a) Consult the ICO Because: r1) A high risk you cannot mitigate requires prior consultation with the ICO.

Prior consultation applies when a high risk remains after the measures.

Common wrong answers.

- `b`: Sign-off records who accepted the risk, but a high residual risk still needs the ICO first.
- `c`: Writing the DPIA does not remove the duty to consult on a high residual risk.
- `d`: Consent does not replace prior consultation, and it is rarely valid for employees.
- `a|r2`: Right action, wrong reason. Only a high risk that remains after measures triggers prior consultation.

E1-L4 exercise 3

Hints. (1) Each scale has three steps. (2) The top of likelihood is more than possible. (3) `probable`, `severe`, `high`.

Answer.

```
Likelihood of harm:  remote, possible, probable
Severity of harm:    minimal, significant, severe
Overall risk:        low, medium, high
```

Remote, possible, probable. Minimal, significant, severe. Low, medium, high.

Common wrong answers.

- g1 = `likely`: The ICO template uses remote, possible, probable.

E1-L4 exercise 4

Hints. (1) Check for an empty list and unknown levels before anything else. (2) Collect every high risk's ID, then sort them. (3) Return `("consult_ico", ids)` only when the list of high IDs is not empty.

Answer.

```python
LEVELS = frozenset({"low", "medium", "high"})


def dpia_outcome(risks: list[dict]) -> tuple[str, list[str]]:
    """Whether a DPIA can proceed or needs prior consultation with the ICO.

    Args:
        risks: Dicts with "id" and "residual" ("low", "medium" or "high").

    Returns:
        ("consult_ico", sorted high-risk IDs) if any residual risk is high,
        otherwise ("proceed", []).

    Raises:
        ValueError: If no risks are given, or a residual level is unknown.
    """
    if not risks:
        raise ValueError("a DPIA with no risks assessed is not finished")
    for risk in risks:
        if risk["residual"] not in LEVELS:
            raise ValueError(f"{risk['id']}: unknown residual level {risk['residual']}")
    high = sorted(risk["id"] for risk in risks if risk["residual"] == "high")
    if high:
        return ("consult_ico", high)
    return ("proceed", [])
```

Validate first, then collect every high residual risk. One high risk is enough to require prior consultation, and the list tells the DPO which.

E1-L4 exercise 5

Hints. (1) What makes a fairness claim checkable? (2) Whose views does Article 35(9) mention? (3) Does the model stay the same for ever?

Answer.

- Fairness is a risk to people, so it needs figures and a trigger in the risk section.
- Article 35(9) and the ICO's monitoring guidance both point to seeking staff views.
- A DPIA describes one version of the processing. When that changes, so must the assessment.

Figures for fairness, recorded staff views, and a review trigger keep the DPIA true to the model as it runs.

Common wrong answers.

- fairness = `statement`: A vendor's claim is not your assessment. Test on your own population, as lesson B13-L3 shows.
- consult = `skip`: Advice to managers still affects how people are treated. Seek views, as lesson E3-L3 explains.
- review = `never`: Models are retrained and purposes drift. A DPIA that never changes stops describing the real processing.

E1-L5 Personal data in each medallion layer

E1-L5 exercise 1

Hints. (1) Which layer keeps the delivery as received? (2) Where do canonical, cleaned tables live? (3) Silver.

Answer. a) Silver

Bronze stays raw for reprocessing. Silver is the first layer most analysts read, so pseudonymise there.

Common wrong answers.

- `b`: Bronze keeps the delivery as received, so reprocessing stays possible.
- `c`: By gold, the readable identifiers have already spread through silver.
- `d`: Access control limits who reads the data. Pseudonymisation limits what a reader learns.

E1-L5 exercise 2

Hints. (1) Who holds the key? (2) Can anyone in the organisation reverse it? (3) Pseudonymised, not anonymous.

Answer. a) Yes Because: r1) The organisation holds the key and can attribute the data to a person, so it is pseudonymised, not anonymous.

You can attribute it with the key you hold, so it remains personal data with a lower risk.

Common wrong answers.

- `b`: Article 4(5) describes pseudonymised data: attributable with the separately kept information. You hold that information.
- `a|r2`: Right answer, wrong reason. Truly anonymous data is not personal data. This data is pseudonymous because you hold the key.

E1-L5 exercise 3

Hints. (1) Very few people read bronze. (2) The hash needs a secret. (3) `engineering`, `keyed`, `suppressed`.

Answer.

```
bronze: raw, read by the pipeline identity and one engineering group
silver: direct identifiers replaced by a keyed hash, key in the secret
    store
gold:   aggregates, with groups under 10 people suppressed
```

Bronze for a named few, a keyed hash in silver, small groups suppressed in gold.

Common wrong answers.

- g2 = `plain`: A plain hash of a known format can be reversed by hashing every possible value. Use a keyed hash.

E1-L5 exercise 4

Hints. (1) Import `hmac` and `hashlib`. (2) Encode the ID to bytes before hashing. (3) Check for an empty ID or key first, and raise `ValueError`.

Answer.

```python
import hashlib
import hmac


def pseudonymise(employee_id: str, key: bytes) -> str:
    """A keyed pseudonym for an employee ID.

    Args:
        employee_id: The direct identifier to replace.
        key: The secret key, read from a secret store at run time.

    Returns:
        The HMAC-SHA256 of the ID under the key, as a hex string.

    Raises:
        ValueError: If the ID or the key is empty.
```

```
    """
    if not employee_id or not key:
        raise ValueError("employee ID and key are both required")
    return hmac.new(key, employee_id.encode("utf-8"),
hashlib.sha256).hexdigest()
```

HMAC-SHA256 with a secret key is deterministic, so joins still work, and it cannot be reversed by hashing every possible ID without the key.

E1-L5 exercise 5

Hints. (1) Who needs raw identifiers? (2) Can a known-format ID be guessed? (3) What does a group of three reveal?

Answer.

- Raw identifiers stay with the few who must reprocess them.
- A keyed hash cannot be matched by hashing every possible ID.
- Small groups in an aggregate can single people out.

Narrow bronze, keyed pseudonyms in silver, and suppression in gold keep each layer's risk in proportion.

Common wrong answers.

- bronze = `all`: Bronze holds raw identifiers. Debugging should use silver, or a named few.
- silver = `plain`: A plain hash of a known ID format is matched by hashing every possible value.
- gold = `show`: A team of three in a ratings report identifies each person.

E2-L1 The DAMA wheel, eleven knowledge areas around governance

E2-L1 exercise 1

Hints. (1) One area decides and oversees how the others run. (2) It holds authority and control over data assets. (3) Data governance.

Answer. b) Data governance

Data governance sits at the hub and directs the ten other knowledge areas.

Common wrong answers.

- `a`: Architecture is one of the ten spokes.
- `c`: Data quality is a spoke. Governance decides the quality rules and who owns them.
- `d`: Metadata management is a spoke.

E2-L1 exercise 2

Hints. (1) Where is the problem: the report or the records? (2) Which area keeps one golden record per person? (3) Reference and master data.

Answer. b) Reference and master data Because: r1) Master data keeps one agreed record per core entity, such as a person.

Duplicate people are a master data problem. The report only exposes them.

Common wrong answers.

- `a`: The report shows the symptom. The duplicate person records cause it.
- `c`: Documents are not involved. The problem is two records for one person.
- `d`: Storage holds the rows. The rule that decides which rows are the same person belongs to master data.
- `b|r2`: Right area, wrong reason. Reference data is a list of codes. One record per person is master data.

E2-L1 exercise 3

Hints. (1) One is a list of allowed values. (2) The other describes data rather than being data. (3) `Reference`, then `Metadata`.

Answer.

```
1 Reference data: a controlled list of codes, such as grades or country
    codes
2 Metadata: data about data, such as definitions, owners and lineage
```

Reference data lists allowed codes. Metadata describes data. Master data is the agreed record itself.

Common wrong answers.

- g1 = `Master`: Master data is the agreed record of a core entity, such as a person. A list of codes is reference data.

E2-L1 exercise 4

Hints. (1) Ask what kind of failure each one is: access, meaning or completeness. (2) Where do agreed definitions live? (3) Completeness is a data quality dimension.

Answer.

- Access to salary is a data security question: masking and roles.
- A shared definition lives in the glossary, part of metadata management.
- Missing managers break a completeness rule, owned by data quality.

Naming the area first sends each problem to an owner who can fix it.

Common wrong answers.

- salary = `quality`: The salaries are correct. The problem is who can see them.
- definition = `architecture`: Layers will not settle a definition. The glossary does.
- missing = `security`: Nothing is exposed. Records are incomplete, which is a quality rule.

E2-L1 exercise 5

Hints. (1) Breadth first, then depth. (2) Who can decide what a field means? (3) Is the wheel about knowledge or about teams?

Answer.

- A full map first shows where the risk sits, not where you are comfortable.
- Named owners per area and domain turn the map into accountability. Gaps are findings.
- The wheel is a checklist. Teams can own several areas.

Map all areas, name owners, and use the wheel to route work, not to reorganise people.

Common wrong answers.

- scope = `one`: Starting where you are comfortable can leave the riskiest area unseen.
- owners = `team`: A platform team cannot own the meaning of HR data. Business owners must.
- use = `org`: The wheel organises knowledge, not people.

E2-L2 A maturity baseline you can defend

E2-L2 exercise 1

Hints. (1) Is there a documented standard? (2) Is it measured? (3) Documented and followed, but not measured.

Answer. b) 3 defined

A documented standard followed across teams is level 3, defined. Measuring it with targets would move it to 4.

Common wrong answers.

- `a`: Initial means ad hoc. A documented standard that every team follows is further along.
- `c`: Managed needs measures and targets. Nobody measures these rules yet.
- `d`: Optimised needs continuous improvement driven by measures.

E2-L2 exercise 2

Hints. (1) What would an average hide? (2) Which score stops an AI pilot in its tracks? (3) Report the minimum and name its area.

Answer. c) 0, with the area that scored it Because: r1) One weak area can sink a domain, and a mean hides it.

Report the weakest area per domain. The other scores still matter for the plan, but the minimum sets the risk.

Common wrong answers.

- `a`: The mean of 3 hides an area with no capability at all.
- `b`: The mode hides the weakest area just as the mean does.
- `d`: A baseline reports where you are today, including the gaps.
- `c|r2`: Right answer, wrong reason. The weakest area can be any of the eleven.

E2-L2 exercise 3

Hints. (1) What must exist before any score? (2) Scores before summaries. (3) Rescoring comes last, on the same scale.

Answer.

1. Agree and version the scale with stakeholders
2. Lay out the grid: knowledge areas by talent domain
3. Score each cell in whole levels, citing evidence
4. Report the weakest area per domain
5. Rescore at a fixed interval on the same scale

Scale, grid, scores with evidence, the weakest area per domain, then rescoring on the same scale.

Common wrong answers.

- Scores mean nothing until the scale is agreed. Agree it first.
- You cannot report the weakest area before you score.

E2-L2 exercise 4

Hints. (1) Validate every score before you pick the minimum. (2) Check `bool` before `int`, because `True` is an `int` in Python. (3) `min(areas.items(), key=lambda pair: (pair[1], pair[0]))` breaks ties by name.

Answer.

```python
MIN_LEVEL = 0
MAX_LEVEL = 5


def weakest_by_domain(scores: dict[str, dict[str, int]]) -> dict[str, tuple[str, int]]:
    """The weakest knowledge area and its score for each talent domain.

    Args:
        scores: Domain to knowledge area to whole-level score.

    Returns:
        Domain to (area, score). Ties go to the area first in alphabetical order.

    Raises:
        ValueError: If a score is not a whole number from 0 to 5, or a domain is empty.
    """
    result: dict[str, tuple[str, int]] = {}
    for domain, areas in scores.items():
        if not areas:
            raise ValueError(f"{domain}: no scores")
        for area, score in areas.items():
            if isinstance(score, bool) or not isinstance(score, int):
                raise ValueError(f"{domain}.{area}: score must be a whole number")
            if not MIN_LEVEL <= score <= MAX_LEVEL:
                raise ValueError(f"{domain}.{area}: score {score} is outside 0 to 5")
        result[domain] = min(areas.items(), key=lambda pair: (pair[1], pair[0]))
    return result
```

Validate first, so a typo such as 2.5 or 6 fails loudly. Then a tuple key picks the lowest score and breaks ties by name, so the result never depends on dict order.

E2-L2 exercise 5

Hints. (1) Which view shows the weakest area? (2) What can an auditor check? (3) What blocks work built on top?

Answer.

- The grid shows where the risk sits. One number cannot.
- Evidence lets anyone check a score, and rescoring use the same proof.
- Targets start with the weakest areas, because they block everything built on top.

Show the grid, cite the evidence, and set targets that fix the weakest areas first.

Common wrong answers.

- headline = `mean`: An average of 3.1 hid a 0 in this lesson's example.
- evidence = `survey`: Perception is not evidence. Cite artefacts.
- next = `pilot`: A high mean can still hide a 0 in security or ownership.

E2-L3 Governance at the hub, decision rights, policies and escalation

E2-L3 exercise 1

Hints. (1) Governance decides. Management does. (2) Which option sets a decision right? (3) Who may approve access.

Answer. b) Deciding who may approve access to salary data

Deciding who holds a decision right is governance. Running, building and granting are management.

Common wrong answers.

- `a`: Running checks is doing the work. Governance sets the thresholds and who owns them.
- `c`: Building a layer is management. Governance sets the rules it must meet.
- `d`: Granting is management. Governance decides who may approve the grant.

E2-L3 exercise 2

Hints. (1) Which one could a test check? (2) Policy says what, standard makes it measurable, procedure says how. (3) The masking rule.

Answer. b) Ratings are masked for every role except HR business partners and the line chain. Because: r1) A standard makes a policy measurable, so you can test whether it holds.

The masking rule is measurable: you can test which roles see unmasked ratings. That makes it a standard.

Common wrong answers.

- `a`: That is the policy: what must be true, and why.
- `c`: That is a procedure: how to do it.
- `d`: That is advice. Nobody can test it.
- `b|r2`: Right answer, wrong reason. A standard is defined by being measurable, not by who signs it.

E2-L3 exercise 3

Hints. (1) The top level states intent. (2) The middle level can be tested. (3) `Policy`, `Standard`, `Procedure`.

Answer.

```
Policy: what must be true, and why. Changes rarely, senior sign-off.
Standard: makes it measurable. Changes when the platform does.
Procedure: how to do it. Changes often.
```

Policy, standard and procedure separate intent, measure and method, so each changes at its own pace.

Common wrong answers.

- g1 = `Standard`; g2 = `Policy`: The policy states the intent. The standard makes it measurable.

E2-L3 exercise 4

Hints. (1) Who gathers the facts? (2) Who decides when owners disagree? (3) Record before you publish.

Answer.

1. The data steward gathers the definitions in use and their impact
2. The data owners of both domains try to agree
3. Without agreement, the governance council decides
4. Record the decision and its reason in the decision log
5. Update the glossary entry and tell the report owners

Steward, owners, council if needed, then the log, then the glossary and the people affected.

Common wrong answers.

- Start at the lowest level that can resolve it. The council is the last resort.
- Log the decision first, so the glossary change points to its reason.

E2-L3 exercise 5

Hints. (1) Who owns the meaning of HR data? (2) Which option can be tested? (3) Which option ends a dispute for good?

Answer.

- The business owns meaning. The platform team builds what the owner decides.
- Three levels of rules make access testable and changeable at the right pace.
- A fixed path with a log ends disputes for good.

Named owners, layered rules and a logged escalation path turn governance from advice into decisions.

Common wrong answers.

- decider = `platform`: Building a table does not give the right to define a rating. That belongs to the business owner.
- rule = `guidance`: Guidance cannot be tested or enforced.
- disputes = `meeting`: Without an owner and a log, the same dispute returns.

E2-L4 People master data, match rules and survivorship

E2-L4 exercise 1

Hints. (1) Survivorship runs after matching. (2) It works field by field. (3) Which value survives.

Answer. a) Which value each field of the golden record takes

Matching finds the records. Survivorship picks each field's value for the golden record.

Common wrong answers.

- `b`: That is the match rule. Survivorship comes after the match.
- `c`: That is access control, a data security question.
- `d`: That is retention.

E2-L4 exercise 2

Hints. (1) Which band holds 0.87? (2) Who decides uncertain pairs? (3) The steward queue.

Answer. a) The pair goes to the data steward queue Because: r1) A score between the bands is uncertain, and a false merge mixes two people's data.

Scores between the two thresholds are uncertain, so a person decides.

Common wrong answers.

- `b`: 0.87 is below the merge band.
- `c`: 0.87 is above the keep-apart band. Someone must decide.
- `d`: Replacing a record loses its source ID and history.
- `a|r2`: Right action, wrong reason. Stewards see only the uncertain band, or the queue would never empty.

E2-L4 exercise 3

Hints. (1) The trusted system wins for legal name. (2) Addresses change over time. (3) `priority`, `recent`, `blank`.

Answer.

```
legal_name:    source priority, the HR system first
home_address:  most recent update wins
any field:     never overwrite a value with a blank
```

Source priority for legal name, most recent for address, and a blank never wins.

Common wrong answers.

- g2 = `complete`: An address changes when someone moves. The latest update is the best guess, so the rule is most recent.

E2-L4 exercise 4

Hints. (1) Check every source against `priority` first. (2) Sort the records by `priority.index` of their source, most trusted first. (3) Take a field only if it is not taken yet and its value `is not None`.

Answer.

```python
def survive(records: list[dict], priority: list[str]) -> dict:
    """The golden record built from matched source records.

    Args:
        records: Matched records, each with a "source" key and field values.
        priority: Source names, most trusted first.

    Returns:
        Each field's value from the most trusted source that has one.

    Raises:
```

```
        ValueError: If a record's source is not in priority.
    """
    for record in records:
        if record["source"] not in priority:
            raise ValueError(f"unknown source: {record['source']}")
    golden: dict = {}
    for record in sorted(records, key=lambda r:
priority.index(r["source"])):
        for field, value in record.items():
            if field != "source" and field not in golden and value is not
None:
                golden[field] = value
    return golden
```

Sorting by trust and taking the first non-missing value per field applies source priority while keeping blanks from winning. `is None` keeps 0 as a real value.

E2-L4 exercise 5

Hints. (1) Which rule cannot collide for two people? (2) Who should decide a doubtful pair? (3) How would you undo a false merge?

Answer.

- Automatic merges need a deterministic key. Name and birth year collide in a large firm.
- A steward decides the uncertain band, because a false merge exposes one person's data to another.
- The cross-reference lets later deliveries find their person and makes an unmerge possible.

Deterministic auto-merge, steward review for the middle band, and a kept cross-reference make the golden record safe to use.

Common wrong answers.

- auto = `name`: Two people often share a name and birth year. That rule caused a reportable breach in this lesson's example.
- uncertain = `merge`: A false merge mixes two people's salaries and ratings. Complaints arrive after the harm.
- xref = `drop`: Without source IDs, the next payroll delivery cannot find its person, and you cannot undo a false merge.

E2-L5 A RACI and a business glossary for talent data

E2-L5 exercise 1

Hints. (1) A owns the outcome. (2) What happens with two owners? (3) Exactly one.

Answer. a) Exactly one

Exactly one accountable role per activity, so one person signs off.

Common wrong answers.

- `b`: Two accountable roles wait for each other or approve different things. Exactly one.
- `c`: Teams can be responsible or consulted. Only one role owns the outcome.
- `d`: Without an A, nobody signs the work off.

E2-L5 exercise 2

Hints. (1) Before or after the decision? (2) One-way or two-way? (3) Consulted.

Answer. a) C Because: r1) Consulted means asked before the decision, in a two-way exchange.

C is asked before the decision; I is told after it.

Common wrong answers.

- `b`: Informed is told after the decision. The DPO's view is needed before it.
- `c`: The performance data owner is accountable for access. The DPO advises.
- `d`: Responsible does the work of granting. The DPO does not.
- `a|r2`: Right letter, wrong reason. Being told afterwards is I. C is asked before.

E2-L5 exercise 3

Hints. (1) How a measure is computed. (2) The A for the definition. (3) `rule`, `owner`, `record`.

Answer.

```
term, definition, calculation rule
owner (accountable for the definition) and steward
system of record
status, version and date approved
```

A calculation rule, an owner and a system of record make a definition usable and checkable.

Common wrong answers.

- g2 = `steward`: The steward maintains the entry. The owner is accountable for the definition.

E2-L5 exercise 4

Hints. (1) For each activity, count the As and the Rs in its letters. (2) Check every letter against R, A, C and I. (3) Collect the messages and return them sorted.

Answer.

```python
VALID_LETTERS = frozenset({"R", "A", "C", "I"})


def raci_problems(raci: dict[str, dict[str, str]]) -> list[str]:
    """Problems in a RACI: missing or duplicate accountable roles, no responsible role, bad letters.

    Args:
        raci: Activity to a dict of role to letter.

    Returns:
        The problems found, sorted. Empty when the RACI is sound.
    """
    problems: list[str] = []
    for activity, cells in raci.items():
        letters = list(cells.values())
        accountable = letters.count("A")
        if accountable == 0:
            problems.append(f"{activity}: no accountable role")
        elif accountable > 1:
            problems.append(f"{activity}: {accountable} accountable roles")
        if letters.count("R") == 0:
            problems.append(f"{activity}: no responsible role")
        for role, letter in cells.items():
            if letter not in VALID_LETTERS:
                problems.append(f"{activity}: unknown letter {letter} for {role}")
    return sorted(problems)
```

Counting As and Rs per activity catches the two failures that stall decisions, and checking letters catches typos before the table is published.

E2-L5 exercise 5

Hints. (1) Where do disputes happen most? (2) What happens when someone leaves? (3) How would a report know the definition changed?

Answer.

- The most-used terms cause most disputes, so they repay the effort first.
- Roles survive reorganisations; names go stale.
- Versioned changes let every report say which definition it used.

Start with the busiest terms, name roles, and version every change.

Common wrong answers.

- scope = `all`: Hundreds of terms at once means none get approved. Start where the disputes are.
- names = `people`: When someone moves on, a name-based RACI points nowhere.
- change = `edit`: An edit in place silently changes every report that uses the term.

E3-L1 Restricted transfers, when people data leaves the UK

E3-L1 exercise 1

Hints. (1) Run the three steps on each option. (2) Step 3 asks whether the receiver is a separate legal person. (3) A sister company is a separate legal person.

Answer. a) A UK company sends appraisal data to its sister company in India

A sister company abroad is a separate legal person outside the UK, so all three steps answer yes.

Common wrong answers.

- `b`: A branch is part of the same legal person, so step 3 of the test fails.
- `c`: Nothing leaves the UK.
- `d`: Deletion sends nothing anywhere.

E3-L1 exercise 2

Hints. (1) Does a transfer need a copy? (2) Who receives the data: your company or another one? (3) Access plus a separate legal person abroad.

Answer. a) Yes Because: r1) Making data available to a separate legal person abroad initiates a transfer, even without a copy.

Granting access is how you initiate the transfer, and the group company is a separate legal person outside the UK.

Common wrong answers.

- `b`: Access counts. You initiate the transfer when you make the data available.
- `a|r2`: Right answer, wrong reason. Your own employee travelling abroad is not a separate legal person. The group company is.

E3-L1 exercise 3

Hints. (1) The first route is a decision about a country. (2) The second route is a contract plus a check. (3) `Adequacy`, `safeguards`, `Exceptions`.

Answer.

```
1. Adequacy regulations: the UK has recognised the destination.
2. Appropriate safeguards, such as the IDTA, with protection not
   materially lower than in the UK.
3. Exceptions, narrow and for occasional transfers.
```

Adequacy, appropriate safeguards, or a narrow exception. Every restricted transfer needs one.

Common wrong answers.

- g3 = `Consent`: Consent is one narrow exception, and it rarely works for employees. The route is called exceptions.

E3-L1 exercise 4

Hints. (1) The three-step test comes first, in its own order. (2) A route only matters once the transfer is restricted. (3) Record last, with every answer.

Answer.

1. Check that UK GDPR applies to the processing
2. Check whether you send the data or make it available outside the UK
3. Check whether the receiver is a separate legal person
4. Choose a route: adequacy, safeguards or an exception
5. Record each answer and the route in the data flow register

The three steps in order, then the route, then a record of each answer and the route.

Common wrong answers.

- Choose a route only after the test shows the transfer is restricted.
- The register needs the route too, so choose it before you record.

E3-L1 exercise 5

Hints. (1) Does access count? (2) Who is the separate legal person? (3) Which route does not depend on employee consent?

Answer.

- Access abroad counts, so test the whole flow, not only file copies.
- Step 3 turns on the legal entity, not the group's brand.
- Use adequacy or a safeguard. Consent from employees is rarely freely given.

Test the flow with access included, name the receiving entity, then use adequacy or a safeguard.

Common wrong answers.

- test = `copies`: Read access from abroad is a transfer too.
- entity = `group`: A group is several legal persons. Step 3 asks about the receiving entity.
- route = `consent`: Employees can rarely refuse an employer freely, so consent is a weak route.

E3-L2 Choosing a transfer mechanism and the transfer risk assessment

E3-L2 exercise 1

Hints. (1) Which route comes first? (2) What does adequacy mean for the destination? (3) Adequacy is enough on its own.

Answer. a) Nothing more for the transfer itself

Adequacy regulations cover the transfer. The rest of UK GDPR, such as a lawful basis, still applies to the processing.

Common wrong answers.

- `b`: Safeguards and a TRA are for destinations without adequacy.
- `c`: Consent is a narrow exception, and adequacy makes it unnecessary.
- `d`: Adequacy regulations need no approval case by case.

E3-L2 exercise 2

Hints. (1) Which option reuses what the group already signs? (2) Does any safeguard skip the TRA? (3) The UK Addendum, with a TRA.

Answer. a) The UK Addendum Because: r1) The Addendum extends the EU clauses the group already uses to UK data.

The Addendum adds UK terms to the EU clauses. A TRA is still required.

Common wrong answers.

- `c`: The EU clauses alone do not cover transfers under UK GDPR. The Addendum adapts them.
- `b`: Consent is a narrow exception, rarely valid for employees.
- `d`: Exceptions suit occasional transfers, not regular group flows.
- `a|r2`: Right safeguard, wrong reason. Every safeguard still needs a TRA.

E3-L2 exercise 3

Hints. (1) Check the routes in order: adequacy, then the safeguard, then the assessment. (2) Use `is None` for the missing assessment, so `False` still means failed. (3) Keep the three safeguard names in a `frozenset` constant.

Answer.

```python
SAFEGUARDS = frozenset({"IDTA", "Addendum", "BCR"})


def transfer_route(adequate: bool, safeguard: str | None, tra_passed: bool | None) -> str:
    """The route for a restricted transfer.

    Args:
        adequate: True if UK adequacy regulations cover the destination.
        safeguard: "IDTA", "Addendum", "BCR", or None if there is none.
        tra_passed: The transfer risk assessment result, or None if not done.

    Returns:
        "adequacy", "safeguards" or "stop".

    Raises:
        ValueError: For an unknown safeguard, or a safeguard with no assessment.
    """
    if adequate:
        return "adequacy"
    if safeguard is None:
        return "stop"
    if safeguard not in SAFEGUARDS:
        raise ValueError(f"unknown safeguard: {safeguard}")
```

```
    if tra_passed is None:
        raise ValueError("complete a transfer risk assessment first")
    return "safeguards" if tra_passed else "stop"
```

Adequacy first, then a known safeguard whose assessment exists and passed. A missing assessment raises, because it is not a failure you can act on: it is work not yet done.

E3-L2 exercise 4

Hints. (1) Which route comes first? (2) When is the assessment done: before or after data moves? (3) Protections follow from the assessment.

Answer.

1. Confirm no adequacy regulations cover the destination
2. Choose a safeguard, such as the IDTA
3. Complete the transfer risk assessment against the data protection test
4. Add protections the assessment calls for, such as pseudonymised identifiers
5. Start the transfer and record the route

Rule out adequacy, choose a safeguard, assess, add protections, then transfer and record.

Common wrong answers.

- The assessment comes before the first transfer, not after.
- Check adequacy first. If it applies, you need no safeguard.

E3-L2 exercise 5

Hints. (1) Is a nightly feed occasional? (2) Does a contract replace the assessment? (3) Which option sends less identifiable data?

Answer.

- A regular group feed needs a safeguard. Exceptions are for occasional transfers.
- Every safeguard needs an assessment, and it goes stale when the destination's law changes.
- Pseudonymised IDs with the key in the UK lower the risk the assessment measures.

A safeguard, a live assessment and minimised data make a regular group transfer defensible.

Common wrong answers.

- mechanism = `exception`: A nightly feed is not occasional. Exceptions do not fit.
- tra = `none`: A signed safeguard still needs a transfer risk assessment.
- minimise = `full`: Send only what the purpose needs. Lesson E1-L2 covers data minimisation.

E3-L3 Works councils and consultation before people analytics or AI

E3-L3 exercise 1

Hints. (1) Which kind of law creates works councils? (2) Does it differ by country? (3) Employment law, country by country.

Answer. a) Employment law in each country, alongside data protection law

Works council rights are employment law, and they differ by country. Data protection law adds its own expectations.

Common wrong answers.

- `b`: UK GDPR asks for views in a DPIA, where appropriate. Works council rights come from employment law.
- `c`: The AI Act adds a duty to inform, for high-risk AI. National employment law applies more widely.
- `d`: A vendor cannot create or remove a legal duty to consult.

E3-L3 exercise 2

Hints. (1) What does the ICO expect before monitoring workers? (2) Where do workers' views get recorded? (3) ICO guidance and Article 35(9).

Answer. a) Consult workers before monitoring, and record their views in the DPIA Because: r1) ICO guidance expects consultation before monitoring, and Article 35(9) asks for data subjects' views where appropriate.

The ICO expects consultation before monitoring unless there is good reason not to, and the DPIA records the views.

Common wrong answers.

- `b`: No works council law does not mean no consultation. ICO guidance expects it before monitoring.
- `c`: Consent is a weak basis for employers. Consultation is a different step from a lawful basis.

- `d`: Consultation comes before monitoring starts.
- `a|r2`: Right action, wrong reason. The UK has no general works council duty. The duty here comes from ICO guidance and the DPIA.

E3-L3 exercise 3

Hints. (1) Germany's right means the council decides with the employer. (2) France's works council has a three-letter name. (3) `co-determination`, `CSE`, `consent`.

Answer.

```
Germany: works council co-determination over systems able to monitor
   behaviour or performance.
France: the CSE must be consulted before new technology goes live.
Netherlands: works council consent right over personnel monitoring
   systems.
```

Co-determination in Germany, CSE consultation in France, a consent right in the Netherlands.

Common wrong answers.

- g3 = `veto`: The Dutch right is a consent right: the decision needs the works council's consent before it takes effect.

E3-L3 exercise 4

Hints. (1) Loop over the distinct countries in sorted order. (2) Use `rules.get` and raise when the result `is None`. (3) Add the country only when `rule["triggers"] & features` is not empty.

Answer.

```python
def consult_before_go_live(
    sites: list[str], features: set[str], rules: dict[str, dict]
) -> list[tuple[str, str]]:
    """The body to consult in each country before go-live.

    Args:
        sites: Country codes where affected employees work. Repeats are
    allowed.
        features: What the tool does, such as "monitoring".
        rules: Country code to {"body": str, "triggers": set[str]}.

    Returns:
        (country, body) for each distinct country the tool triggers,
    sorted by country.

    Raises:
        ValueError: If a country has no rule.
    """
```

```
    plan: list[tuple[str, str]] = []
    for country in sorted(set(sites)):
        rule = rules.get(country)
        if rule is None:
            raise ValueError(f"no consultation rule for {country}")
        if rule["triggers"] & features:
            plan.append((country, rule["body"]))
    return plan
```

Distinct sites in order, a loud failure for any unassessed country, and the tool's features decide each duty.

E3-L3 exercise 5

Hints. (1) Do works council rights apply before or after use? (2) Do the three processes finish on the same day? (3) Where does Article 35(9) put the views you gather?

Answer.

- Consultation comes before use. A French court can suspend a tool deployed before the CSE gives its opinion.
- Each country's process runs at its own pace, so the roll-out follows it.
- The DPIA is where views of data subjects and representatives belong.

Consult before go-live, roll out as each country clears, and keep the views in the DPIA.

Common wrong answers.

- when = `after`: German co-determination and French consultation both come before use.
- rollout = `same_day`: One country's process can take months. A single date forces a launch before some consultations finish.
- record = `email`: The DPIA records views of data subjects and representatives. An inbox is not a record anyone will find.